

テクノロジー系試験範囲

1. 基礎理論

1-1. 基礎理論

離散数学/応用数学/情報に関する理論/通信に関する理論/継続・制御に関する理論

1-2. アルゴリズムとプログラミング

データ構造/アルゴリズム/プログラミング/プログラム言語/その他の言語

2. コンピュータシステム

2-1. コンピュータ構成要素

プロセッサ/メモリ/バス/入出力デバイス/入出力装置

2-2. システム構成要素

システムの構成/システムの評価指標

2-3. ソフトウェア

オペレーティングシステム/ミドルウェア/ファイルシステム/開発ツール/オープンソースソフトウェア

2-4. ハードウェア

ハードウェア

テクノロジー系試験範囲

3. 技術要素

3-1. ヒューマンインターフェース

ヒューマンインターフェース技術/インタフェース設計

3-2. マルチメディア

マルチメディア技術/マルチメディア応用

3-3. データベース

データベース方式/データベース設計/データ操作/トランザクション処理/データベース応用

3-4. ネットワーク

ネットワーク方式/データ通信と制御/通信プロトコル/ネットワーク管理/ネットワーク応用

3-5. セキュリティ

情報セキュリティ/情報セキュリティ管理/セキュリティ技術評価/情報セキュリティ対策/情報セキュリティ実装技術

4. 開発技術

4-1. システム開発技術

システム要件定義/システム方式設計/ソフトウェア要件定義/ソフトウェア方式設計・ソフトウェア詳細設計/ソフトウェア構築/ソフトウェア結合・ソフトウェア適格性確認テスト/ソフトウェア結合・ソフトウェア適格性確認テスト/システム結合・システム適格性確認テスト/導入/受入れ支援/保守・廃棄

4-2. ソフトウェア開発管理技術

開発プロセス・手法/知的財産権運用管理/開発環境管理/構成管理・変更管理

技術要素

セキュリティ

情報セキュリティ、情報セキュリティ管理

目標：

- 情報セキュリティの目的，考え方，重要性を修得する。
- 情報資産に対する脅威，脆弱性と主な攻撃手法の種類を修得する。
- 情報セキュリティに関する技術の種類，仕組み，特徴，その技術を使用することで，どのような脅威を防止できるかを修得する。
- 情報セキュリティ管理の考え方を修得する。
- リスク分析と評価などの方法，手順を修得する。
- 情報セキュリティ継続の考え方を修得する。
- 情報セキュリティ諸規程（情報セキュリティポリシーを含む組織内規程）の目的，考え方を修得する。
- 情報セキュリティマネジメントシステム（ISMS）や情報セキュリティに係るその他の基準の考え方，情報セキュリティ組織・機関の役割を修得する。

サイバー攻撃

システムを破壊することを目的として、**大量のデータを送りつけたり、不正侵入してデータを盗んだり・改竄するような攻撃の総称**。コンピュータやネットワークの中に広がるデータ領域を、多数の利用者が自由に情報を流したり情報を得たりすることが出来る仮想的な空間を**サイバー空間**と言う

情報資産

企業が守るべきデータ。顧客情報，営業情報，知的財産関連情報，人事情報など



これらを守るために**情報セキュリティ対策**が必要

システムの脅威と脆弱性一覧

- ①. 人的脅威・・・直接、人が関わる攻撃
- ②. 技術的脅威・・・マルウェア（不正かつ有害に動作させる意図で作成された悪意のあるソフトウェアや悪質なコードの総称）を用いた攻撃。ソフトウェアによる攻撃
- ③. 物理的脅威・・・物理的に破壊させる行為
- ④. 脆弱性・・・セキュリティ上の欠陥
- ⑤. 不正・・・内部のものがシステムの破壊を行うこと

脅威と脆弱性

① 人的脅威の種類と特徴

なりすまし	盗んだIDとパスワードを用いて、正規のユーザのように操作して情報を盗むこと
クラッキング	ネットワークを通じて他人のPCやシステムに侵入して中の情報を盗んだり、破壊したりすること
ソーシャルエンジニアリング	本人を装ってパスワードを聞き出したり、緊急を装って組織の機密情報を聞き出すこと

② 技術的脅威の種類と特徴

ワーム	ネットワークやマルチメディアを通じて複製をしながらコンピュータを移動することで増殖するウイルス
スパイウェア	ユーザが認識せずに悪意のあるプログラムをインストールさせて個人情報盗むプログラム
ランサムウェア	ファイルを使用不能にして、回復するために金銭を要求する
ボット(BOT)	ネットワークを通じて他人のPCを操り、情報を盗んだり他のサイトを攻撃する。
トロイの木馬	有用なソフトに見せてインストール後に悪意のある動作をするソフト
ルートキット (rootkit)	サーバにバックドアを作り、サーバ内で侵入の痕跡を隠蔽するなどの機能がパッケージ化された不正なプログラムやツールのこと

RAT	Remote Access Tool。物理的に離れた場所から、システムにアクセスしてシステムを悪用するソフトウェアの総称
マクロウイルス	マクロとは、マイクロソフトのExcelなどのOfficeで利用されているマクロ言語のこと。Officeのファイルを開いた場合に、マクロが実行されウイルスに感染する
ガンブラー	WebサイトのWebサーバをウイルスで感染させる。そのWebサイトに訪問したユーザのPCもウイルスに感染させる
キーロガー	コンピュータ（パーソナルコンピュータ）へのキー入力を監視してそれを記録するソフトウェアもしくはハードウェア。キーの入力からパスワードを盗み出す。
バックドア	一度侵入したコンピュータに、後から何度もログインできるように仕掛ける入り口のこと
SPAM	受信者の意向を無視して無差別かつ大量に一括してばらまかれる各種メディアにおけるメッセージ（メール）

③ 物理的脅威



災害、破壊など

④ 脆弱性

情報システムの情報セキュリティに関する欠陥，行動規範の組織での未整備，従業員への不徹底など

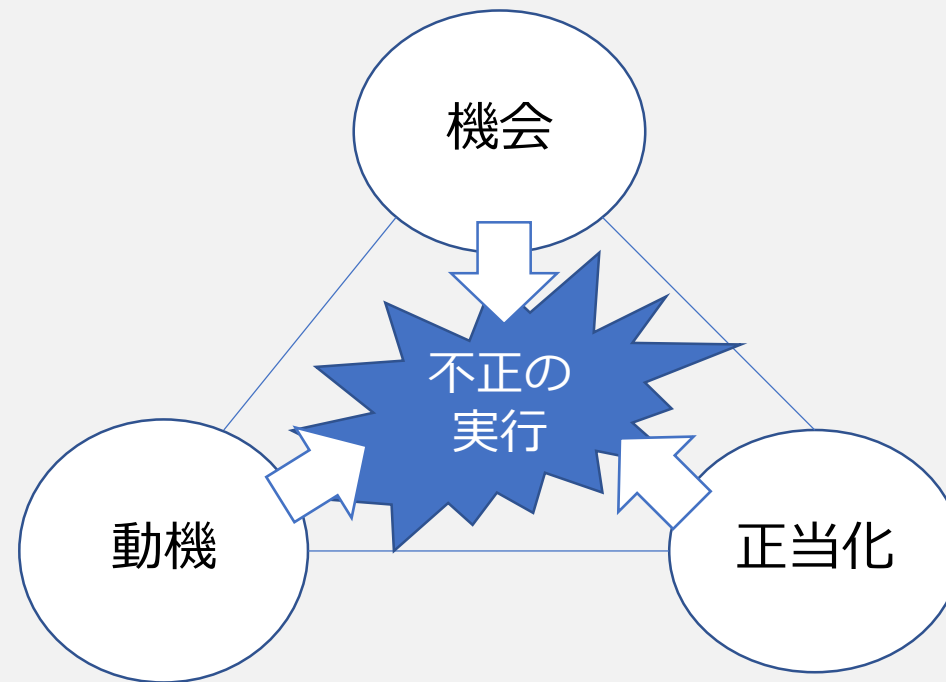
セキュリティホール	プログラムのバグ、設計上の問題によって生じるセキュリティ上の欠陥のこと
バグ	コンピュータのプログラム上の誤り・ミス
人的脆弱性	プログラム上のミスや、セキュリティのずさんな管理など。人的なミスによって生じる脆弱性のこと
シャドーIT	従業員が、企業のIT部門の許可を得ていないデバイスを使用すること。デバイスにセキュリティ設定が適切にされていない場合には情報漏洩のリスクがある

ハッカー、クラッカー 等

クラッカー	サイバー攻撃などのコンピュータ犯罪を行う攻撃者
ホワイトハッカー	サイバー攻撃からシステムを守る
スクリプトキディ	攻撃用ツールを興味本位で利用するもののこと
ボットハーダー	マルウェアに感染したPCを踏み台とするボットネットを構築し、「c&cサーバー」と呼ばれるマシンによってボットネットに命令を送り、サイバー攻撃を行う

⑤ 不正のメカニズム

不正のトライアングル（機会、動機、正当化）



機会	情報システムの脆弱性などの不正行為を実行しやすくする環境が与えられていること
動機	従業員の待遇の不満など不正を働きたくなるきっかけ
正当化	不正行為をする口実やこじつけなど、自らの行為を納得させるための理由付け

基本情報技術者平成28年春期 午前問38

スパイウェアに該当するものはどれか。

ア. Webサイトへの不正な入力を排除するために、Webサイトの入力フォームの入力データから、HTMLタグ、JavaScript、SQL文などを検出し、それらを他の文字列に置き換えるプログラム

→誤り。サニタイジングの説明です。

イ.サーバへの侵入口となり得る脆弱なポートを探すために、攻撃者のPCからサーバのTCPポートに順番にアクセスするプログラム

→誤り。ポートスキャンツールです

ウ.利用者の意図に反してPCにインストールされ、利用者の個人情報やアクセス履歴などの情報を収集するプログラム

→正しい。スパイウェアはユーザが認識せずに悪意のあるプログラムをインストールさせて個人情報を盗むプログラムです

エ.利用者のパスワードを調べるために、サーバにアクセスし、辞書に載っている単語を総当たりで試すプログラム

→誤り。辞書攻撃の説明です

基本情報技術者平成31年春期 午前問42

不正が発生する際には"不正のトライアングル"の3要素全てが存在すると考えられている。"不正のトライアングル"の構成要素の説明として、適切なものはどれか。

ア."機会"とは、情報システムなどの技術や物理的な環境、組織のルールなど、内部者による不正行為の実行を可能又は容易にする環境の存在である。

→正しい。機会の説明です

イ."情報と伝達"とは、必要な情報が識別、把握及び処理され、組織内外及び関係者相互に正しく伝えられるようにすることである。

→誤り。情報と伝達は不正のトライアングルの要素ではありません

ウ."正当化"とは、ノルマによるプレッシャなどのことである。

→誤り。正当化は不正行為をする口実やこじつけなど、自らの行為を納得させるための理由付け

エ."動機"とは、良心のかしゃくを乗り越える都合の良い解釈や他人への責任転嫁など、内部者が不正行為を自ら納得させるための自分勝手な理由付けである。

→誤り。動機は従業員の待遇の不満など不正を働きたくなるきっかけです

基本情報技術者平成27年春期 午前問37

キーロガーの悪用例はどれか。

ア.通信を行う2者間の経路上に割り込み，両者が交換する情報を収集し，改ざんする。

→誤り。中間者攻撃の説明です

イ.ネットバンキング利用時に，利用者が入力したパスワードを収集する。

→正しい。キーロガーはキーボードの入力を記録するものでこれはキーロガーの悪用例です

ウ.ブラウザでの動画閲覧時に，利用者の意図しない広告を勝手に表示する。

→誤り。アドウェアを悪用した例です

エ.ブラウザの起動時に，利用者がインストールしていないツールバーを勝手に表示する。

→誤り。ブラウザのアドオンを悪用した攻撃です

応用情報技術者平成22年秋期 午前問39

ソーシャルエンジニアリングに分類される手口はどれか。

ア.ウイルス感染で自動作成されたバックドアからシステムに侵入する。

→誤り。バックドアを利用した攻撃です

イ.システム管理者などを装い，利用者に問い合わせでパスワードを取得する。

→正しい。ソーシャルエンジニアリングは本人を装ってパスワードを聞き出したり、緊急を装って組織の機密情報を聞き出すことです

ウ.総当たり攻撃ツールを用いてパスワードを解析する。

→誤り。総当たり攻撃はソーシャルエンジニアリングではないです

エ.バッファオーバーフローなどのソフトウェアの脆弱性を利用してシステムに侵入する。

→誤り。ソフトウェアの脆弱性を用いたものはソーシャルエンジニアリングではないです

基本情報技術者平成29年秋期 午前問41

マルウェアについて、トロイの木馬とワームを比較したとき、ワームの特徴はどれか。

ア.勝手にファイルを暗号化して正常に読めなくする。

→誤り。ランサムウェアです

イ.単独のプログラムとして不正な動作を行う。

→誤り。トロイの木馬も単独のプログラムとして不正の動作をすることは可能です

ウ.特定の条件になるまで活動をせずに待機する。

→誤り。トロイの木馬の説明です

エ.ネットワークやリムーバブルメディアを媒介として自ら感染を広げる。

→正しい。ワームの説明となっています

基本情報技術者令和元年秋期 午前問39

情報セキュリティにおいてバックドアに該当するものはどれか。

ア.アクセスする際にパスワード認証などの正規の手続きが必要なWebサイトに、当該手続きを経ないでアクセス可能なURL

→正しい。バックドアの説明となっています。バックドアは一度侵入したコンピュータに、後から何度もログインできるように仕掛ける入り口のことです

イ.インターネットに公開されているサーバのTCPポートの中からアクティブになっているポートを探して、稼働中のサービスを特定するためのツール

→誤り。ポートスキャナの説明です

ウ.ネットワーク上の通信パケットを取得して通信内容を見るために設けられたスイッチのLANポート

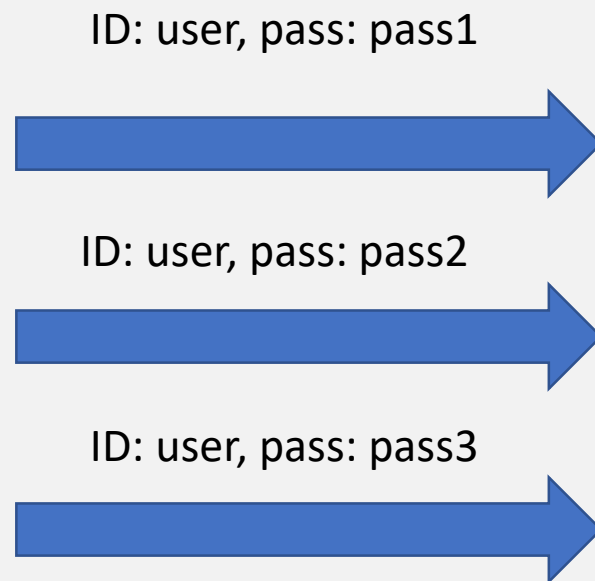
→誤り。これはミラーポートと呼ばれています

エ.プログラムが確保するメモリ領域に、領域の大きさを超える長さの文字列を入力してあふれさせ、ダウンさせる攻撃

→誤り。バッファオーバーフローの説明となっています

攻撃手法

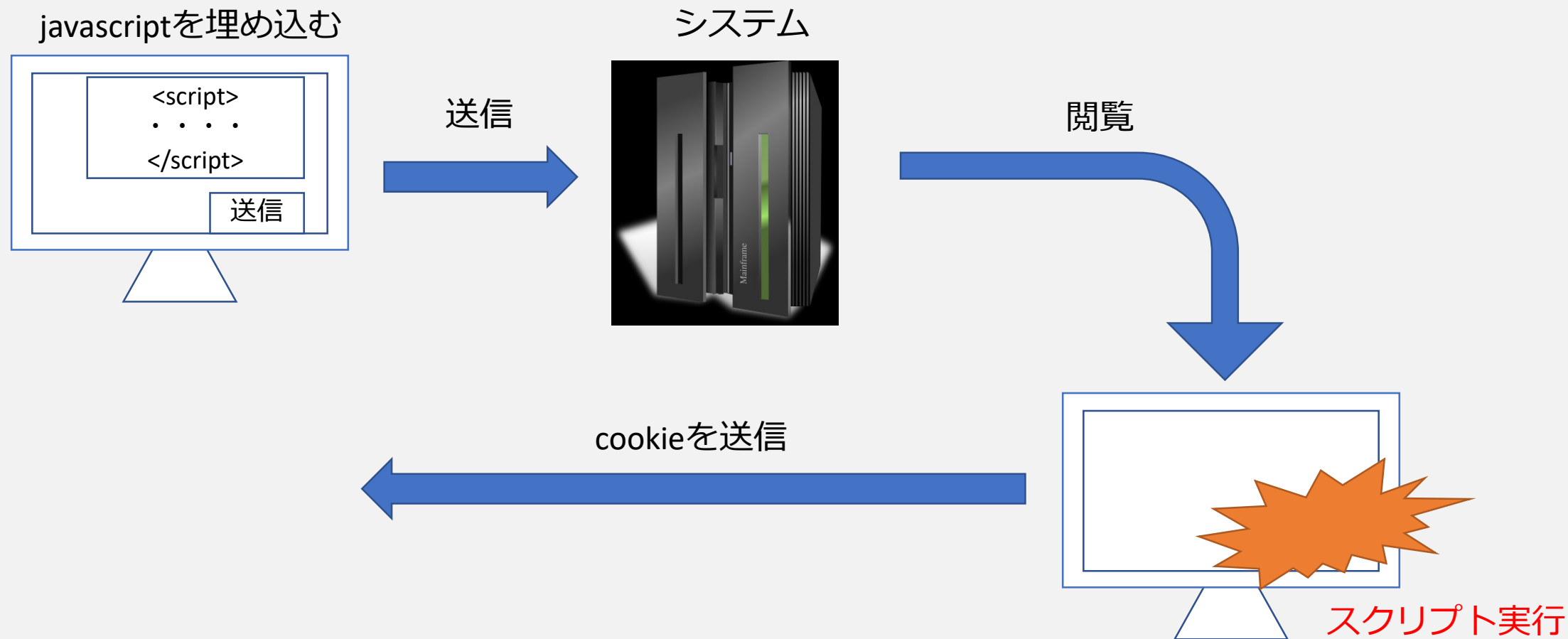
① 総当たり（ブルートフォース）攻撃: あらゆる文字列を試してログインを試みる攻撃。辞書に載っている単語から試すものを**辞書攻撃**。一度、他のサービスから流出したIDとパスワードを用いて不正ログインを試す攻撃を**パスワードリスト攻撃**と言う



対策（システム側）:二段階認証を用いる など

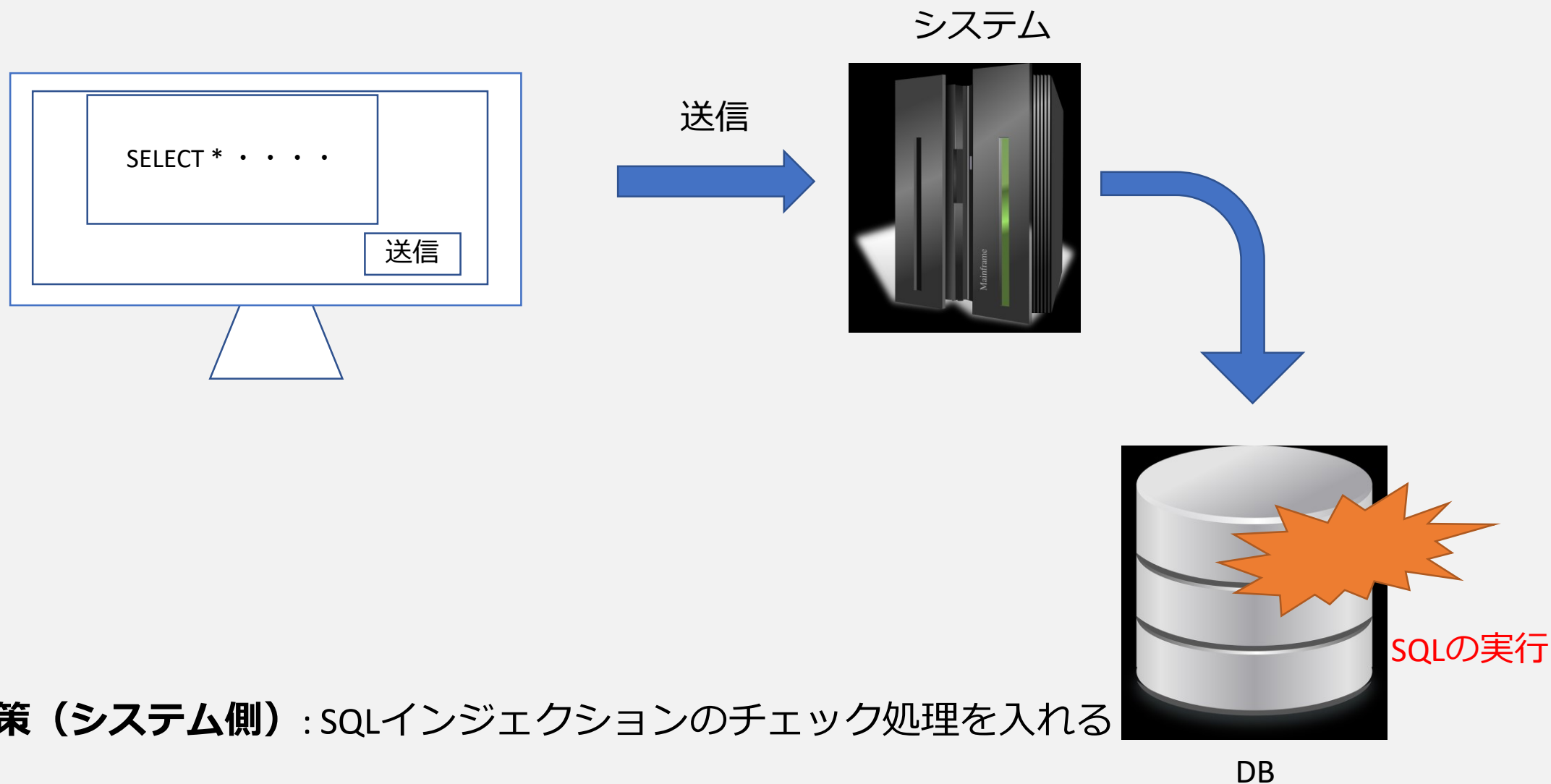
対策（ユーザ側）:パスワードを複雑にする。パスワードを定期的に変更する など

② クロスサイトスクリプティング: Webサイトの脆弱性を利用した攻撃手法。攻撃者は、スクリプト(javascript)付きの入力を行い、他のユーザのブラウザ上で実行させて、cookieなどの情報を盗む



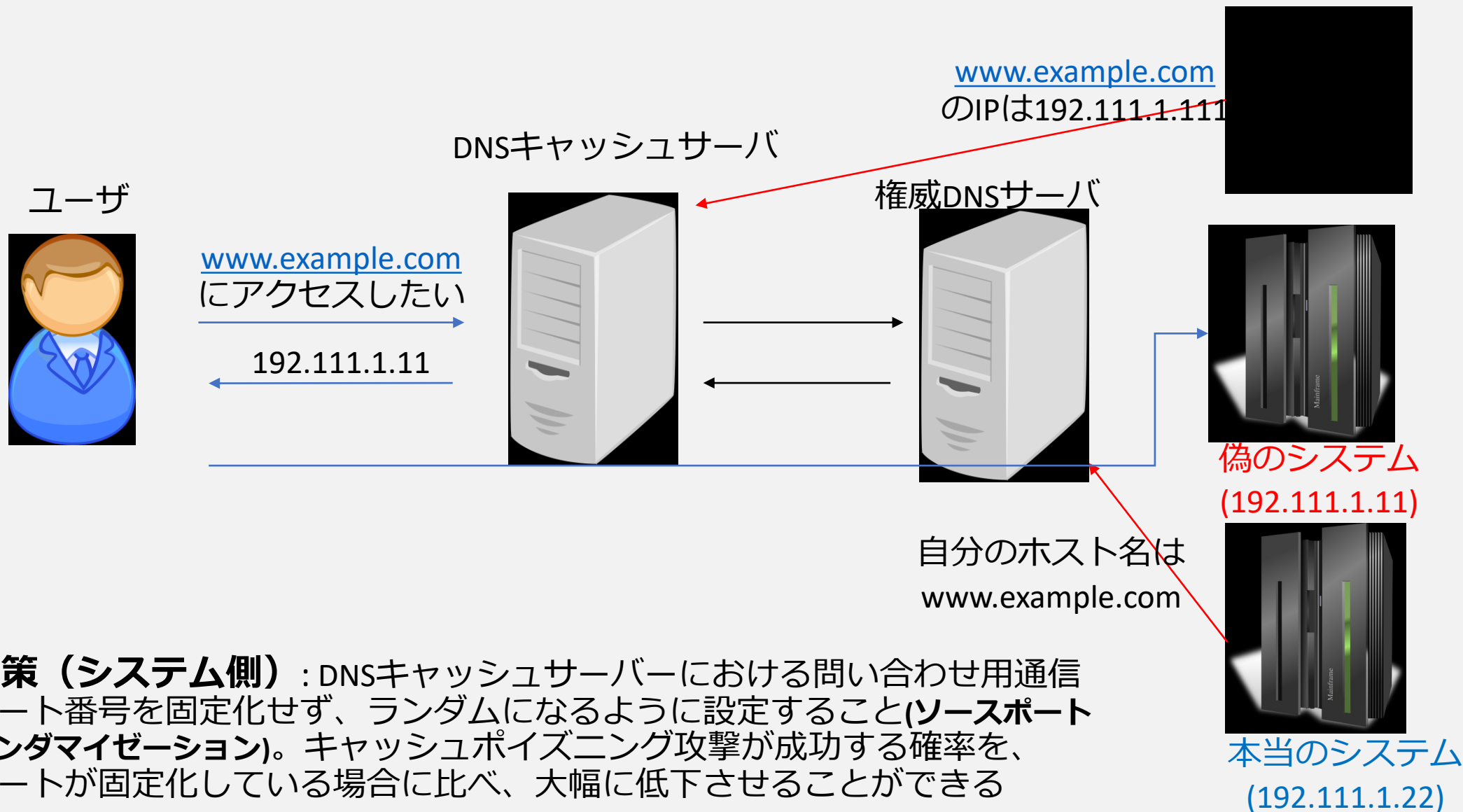
対策 (システム側) : システムにクロスサイトスクリプティングのチェック処理を入れる

③ SQLインジェクション: webサイトの画面からデータを送信する場合に、悪意のあるSQLを書いたデータを送信して、システムが想定していないSQLを実行させ、データを盗み出す。または、データを改ざんする



対策（システム側）: SQLインジェクションのチェック処理を入れる

④ DNSキャッシュポイズニング: DNSキャッシュサーバ（ホストとIPアドレス情報の変換を行うサーバ）のデータを書き換えてユーザを悪意のあるサイトに誘導する攻撃手法



⑤ その他の攻撃

標的型攻撃	無差別でなく、特定の組織に対して、マルウェアに感染させるなどの攻撃をすること。対象組織が利用しているWebサイトを改ざんし、ユーザが利用した場合にマルウェアがダウンロードされるようにする攻撃を 水飲み場型攻撃 という。
フィッシング詐欺	他のサイトを装った偽のWebサイトやメールを用いて、暗証番号をだまし取る詐欺
ワンクリック詐欺	ユーザがWebサイト上のリンクをクリックしただけで、契約完了の画面を表示させ、料金を請求する詐欺
ドライブバイダウンロード	Webサイトを閲覧したときに、悪意のあるソフトウェアを自動的にダウンロードさせる攻撃手法
DOS攻撃、DDOS攻撃	サーバに対して大量にデータを送信して、サーバの機能を停止させる攻撃。複数のサーバから攻撃するものを DDOS攻撃 という。
ゼロデイ攻撃	ソフトウェアにセキュリティホールが発見された場合に、そのソフトウェアのパッチが配布される前にセキュリティホールを狙って攻撃すること
バッファオーバーフロー攻撃	プログラムの想定データ量を超えるデータが発生して、正常に動作しなくなる状態（バッファオーバーフロー）をわざと引き起こす攻撃手法。
MITB(Man In The Browser)攻撃	ユーザのWebブラウザを乗っ取り、WebブラウザとWebサーバ間の通信を監視して、情報の盗聴、改ざんなどをする攻撃手法。
MITM(Man In The Middle)攻撃	中間者攻撃。通信の間に入ってメッセージの改ざんや取得などを行う攻撃。正規サイトに似た中継サイトを作ってログインIDとパスワードを入力させて盗むなど

基本情報技術者平成29年春期 午前問38

共通鍵暗号の鍵を見つけ出そうとする，ブルートフォース攻撃に該当するものはどれか。

ア.一組みの平文と暗号文が与えられたとき，全ての鍵候補を一つずつ試して鍵を見つけ出す。

→正しい。ブルートフォース攻撃の説明です

イ.平文と暗号文と鍵の関係を表す代数式を手掛かりにして鍵を見つけ出す。

→誤り。線形解読法の説明です

ウ.平文の一部分の情報と，暗号文の一部分の情報との間の統計的相関を手掛かりにして鍵を見つけ出す。

→誤り。関連鍵攻撃の説明です

エ.平文を一定量変化させたときの暗号文の変化から鍵を見つけ出す。

→誤り。差分解読法の説明です

応用情報技術者平成25年秋期 午前問42

クロスサイトスクリプティングの手口はどれか。

ア. Webアプリケーションに用意された入力フィールドに，悪意のあるJavaScriptコードを含んだデータを入力する。

→正しい。クロスサイトスクリプティングの説明です

イ.インターネットなどのネットワークを通じてサーバに不正にアクセスしたり，データの改ざん・破壊を行ったりする。

→誤り。クラッキングです

ウ.大量のデータをWebアプリケーションに送ることによって，用意されたバッファ領域をあふれさせる。

→誤り。バッファオーバーフローです

エ.パス名を推定することによって，本来は認証された後にしかアクセスが許可されていないページに直接ジャンプする。

→誤り。ディレクトリトラバーサルです

応用情報技術者平成29年秋期 午前問40

ドライブバイダウンロード攻撃の説明はどれか。

ア. PCにUSBメモリが接続されたとき、USBメモリに保存されているプログラムを自動的に実行する機能を用いてマルウェアを実行し、PCをマルウェアに感染させる。

→誤り。ドライブバイダウンロードはWebサイトにアクセス時にダウンロードされます

イ. PCに格納されているファイルを勝手に暗号化して、復号することと引換えに金銭を要求する。

→誤り。ランサムウェアです

ウ. 不正にアクセスする目的で、建物の外部に漏れた無線LANの電波を傍受して、セキュリティの設定が脆弱な無線LANのアクセスポイントを見つけ出す。

→誤り。ウォードライビングの説明です

エ. 利用者がWebサイトを閲覧したとき、利用者に気付かれないように、利用者のPCに不正プログラムを転送させる。

→正しい

応用情報技術者平成26年秋期 午前問40

Webアプリケーションにおけるセキュリティ上の脅威と対策の適切な組合せはどれか。

ア. OSコマンドインジェクションを防ぐために、Webアプリケーションが発行するセッションIDを推測困難なものにする。

→誤り。セッションハイジャックの対策です

イ. SQLインジェクションを防ぐために、Webアプリケーション内でデータベースへの問合せを作成する際にバインド機構を使用する。

→正しい。SQLインジェクションとその対策の説明です

ウ. クロスサイトスクリプティングを防ぐために、外部から渡す入力データをWebサーバ内のファイル名として直接指定しない。

→誤り。ディレクトリトラバーサル対策です

エ. セッションハイジャックを防ぐために、Webアプリケーションからシェルを起動できないようにする。

→誤り。osコマンドインジェクションの説明です。

応用情報技術者平成23年特別 午前問44

ゼロデイ攻撃の特徴はどれか

ア.セキュリティパッチが提供される前に攻撃する。

→正しい。Zero Day Attackのことで、ゼロデイ攻撃の説明です

イ.特定のサイトに対し、日時を決めて、複数台のPCから同時に攻撃する。

→誤り。DDOS攻撃の説明です

ウ.特定のターゲットに対し、フィッシングメールを送信して不正サイトへ誘導する。

→誤り。フィッシングの説明です

エ.不正中継が可能なメールサーバを見つけた後、それを踏み台にチェーンメールを大量に送信する。

→誤り。スパムメールの説明です

応用情報技術者平成28年春期 午前問45

Man-in-the-Browser攻撃に該当するものはどれか。

ア. DNSサーバのキャッシュを不正に書き換えて、インターネットバンキングに見せかけた偽サイトをWebブラウザに表示させる。

→誤り。DNSキャッシュポイズニングの説明です

イ. PCに侵入したマルウェアが、利用者のインターネットバンキングへのログインを検知して、Webブラウザから送信される振込先などのデータを改ざんする。

→正しい。Man-In-The-Browser攻撃です

ウ.インターネットバンキングから送信されたように見せかけた電子メールに偽サイトのURLを記載しておき、その偽サイトに接続させて、Webブラウザから口座番号やクレジットカード番号を入力させることで情報を盗み出す。

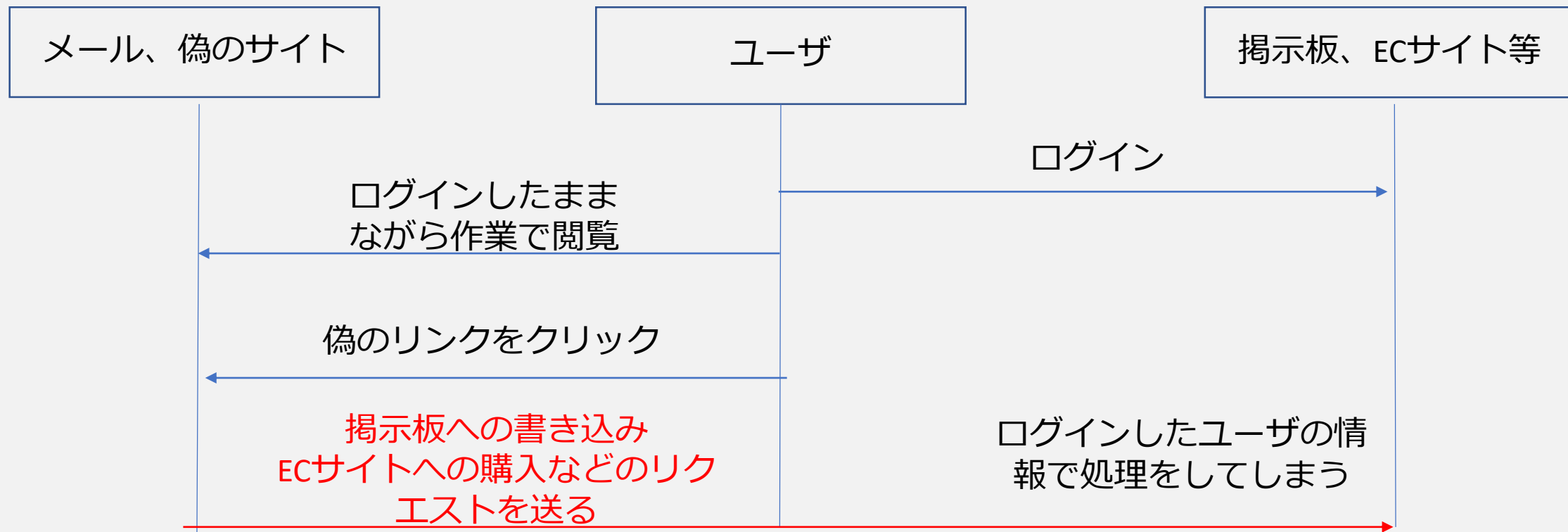
→誤り。フィッシング攻撃の説明です

エ.インターネットバンキングの正規サイトに見せかけた中継サイトに接続させ、Webブラウザから入力された利用者IDとパスワードを正規サイトに転送し、利用者になりすましてログインする。

→誤り。中継サイトを使って情報を取る攻撃はMan-In-The-Middle攻撃です

攻撃手法(クロスサイトリクエストフォージェリ(CSRF))

メールやSNS、他のサイトを通じて、標的となるページに強制的にリクエストを送らせて、掲示板の書き込み、オンラインショッピングでの注文をさせる



対策・・・重要な処理の場合にはパスワードを要求させる。**csrf_token**を利用する(乱数文字列で対象の掲示板、ECサイトでの遷移しか処理を受け付けないようにする仕組み)。**CAPTCHA**（後述）を利用してプログラムでの処理でなく人間の入力であることを保証する

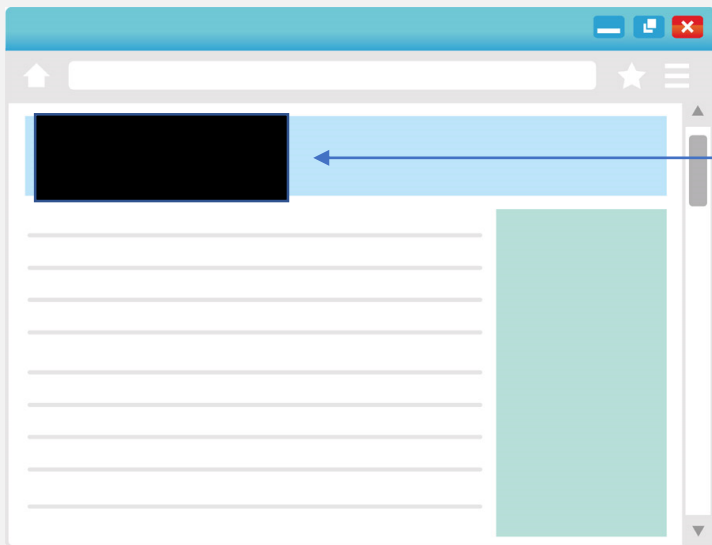
CAPTCHA

機械では判別できないゆがんだ文字の画像を表示して人間に入力させ、人間の入力を保証する。



クリックジャッキング

ユーザーが利用するWebブラウザを悪用したサイバー攻撃の一種。ボタンやリンクなどを透明で見えない状態にして、通常のWebページの上にかぶせてしまうなど

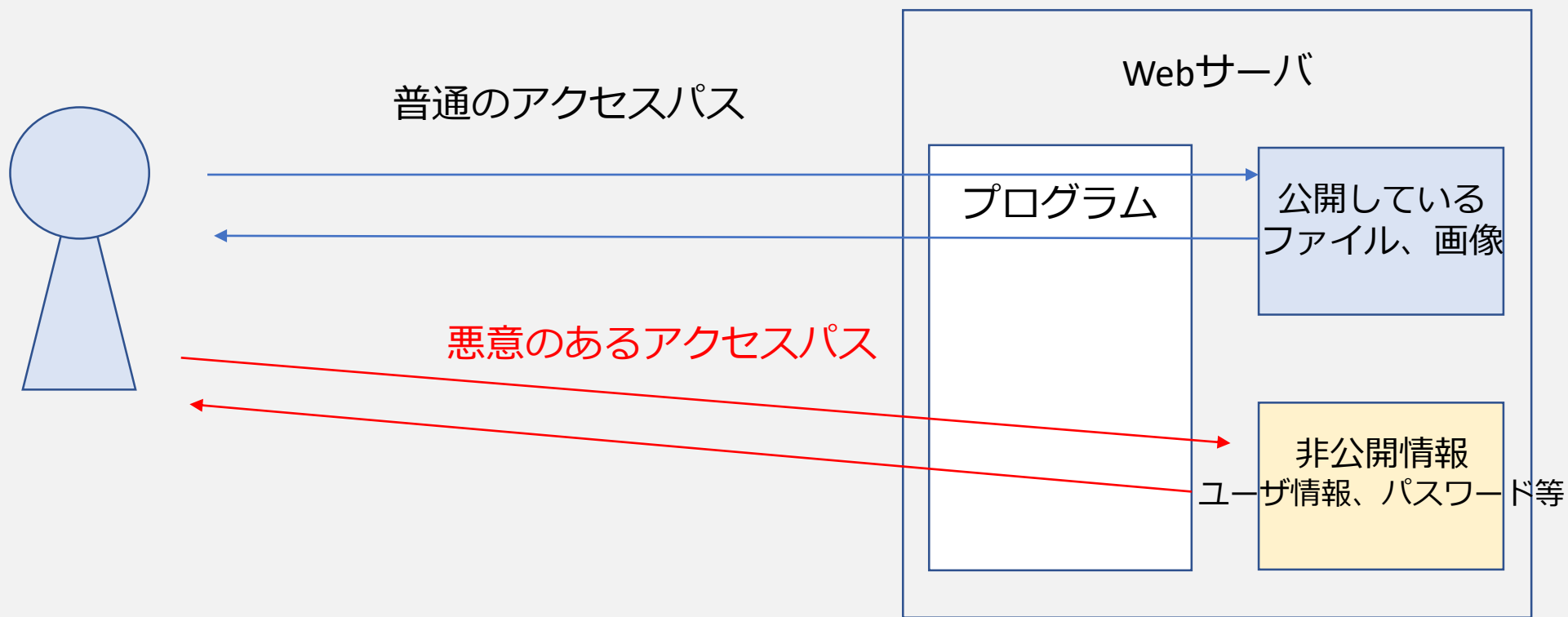


透明ボタン

これを押すと別のサイトに移動したり、悪意のあるリクエストを送るなどをする

ディレクトリトラバーサル

アクセスを禁止しているファイルやディレクトリを、プログラムに表示させる不正なアクセスをする攻撃



対策・・・パス付のファイル名が入力された場合にパスを削除するなどの制御をプログラム内で行う

その他の代表的な攻撃

ドメイン名ハイジャック	DNSサーバーに登録されているドメイン名を書き換えて、特定のドメイン名にアクセスした時に、正規のWebサイトではなく偽のWebサイトへと誘導する手口
セッションハイジャック	コンピューター通信で利用する「セッション」を窃取し、本人に成り代わって通信を行うというサイバー攻撃。セッションは、WEBサイトにアクセスする際に各ユーザに割り振られるID。セッションIDを解読困難なものにして防ぐ
リプレイ攻撃	ユーザーがログインする際に、ネットワークを流れるデータを盗聴して、そのデータを認証サーバーへ送って、システムへ不正にログインする攻撃
IPスプーフィング	送信元のIPアドレスを偽装する攻撃手法。偽装することで、ファイアウォールのIPアドレス制限を突破したり、DoS攻撃などを行う際、攻撃元の特定を困難にしたりする
Wanna Cryptor	コンピュータのデータを読めなくしたり機能を使えなくして、解除する場合に金銭を要求をするランサムウェア
SEOポイズニング	Web検索サイトの上位に悪意のあるサイトが並ぶように細工してユーザを誘導する攻撃
サラミ法	1つの資産から大量に搾取すると攻撃が表面化しやすいため、複数の資産から少しずつ搾取する攻撃

基本情報技術者平成31年春期 午前問36

CAPTCHAの目的はどれか。

ア. Webサイトなどにおいて、コンピュータではなく人間がアクセスしていることを確認する。

→正しい。機械では判別できないゆがんだ文字の画像を表示して人間に入力させ、人間の入力を保証します

イ. 公開鍵暗号と共通鍵暗号を組み合わせ、メッセージを効率よく暗号化する。

→誤り。ハイブリッド暗号方式です

ウ. 通信回線を流れるパケットをキャプチャして、パケットの内容の表示や解析、集計を行う。

→誤り。パケットキャプチャの説明です

エ. 電子政府推奨暗号の安全性を評価し、暗号技術の適切な実装法、運用法を調査、検討する。

→誤り。CRYPTRECの説明です

応用情報技術者平成30年春期 午前問38

ディレクトリトラバーサル攻撃はどれか。

ア. OSコマンドを受け付けるアプリケーションに対して、攻撃者が、ディレクトリを作成するOSコマンドの文字列を入力して実行させる。

→誤り。OSコマンドインジェクションの説明です

イ. SQL文のリテラル部分の生成処理に問題があるアプリケーションに対して、攻撃者が、任意のSQL文を渡して実行させる。

→誤り。SQLインジェクションの説明です

ウ. シングルサインオンを提供するディレクトリサービスに対して、攻撃者が、不正に入手した認証情報を用いてログインし、複数のアプリケーションを不正使用する。

→誤り。不正アクセスです

エ. 入力文字列からアクセスするファイル名を組み立てるアプリケーションに対して、攻撃者が、上位のディレクトリを意味する文字列を入力して、非公開のファイルにアクセスする。

→正しい。ディレクトリトラバーサルの説明です

暗号技術

暗号化方式

共通鍵暗号方式

暗号化と復号に**同じ鍵**を用いる

AES・・・最も一般的に用いられている暗号規格。米国の国家暗号規格

DES・・・AESの前に用いられていた暗号規格

IDEA・・・暗号化するデータを64ビットごとに区切り、128ビットの暗号鍵によって変換する

公開鍵暗号方式

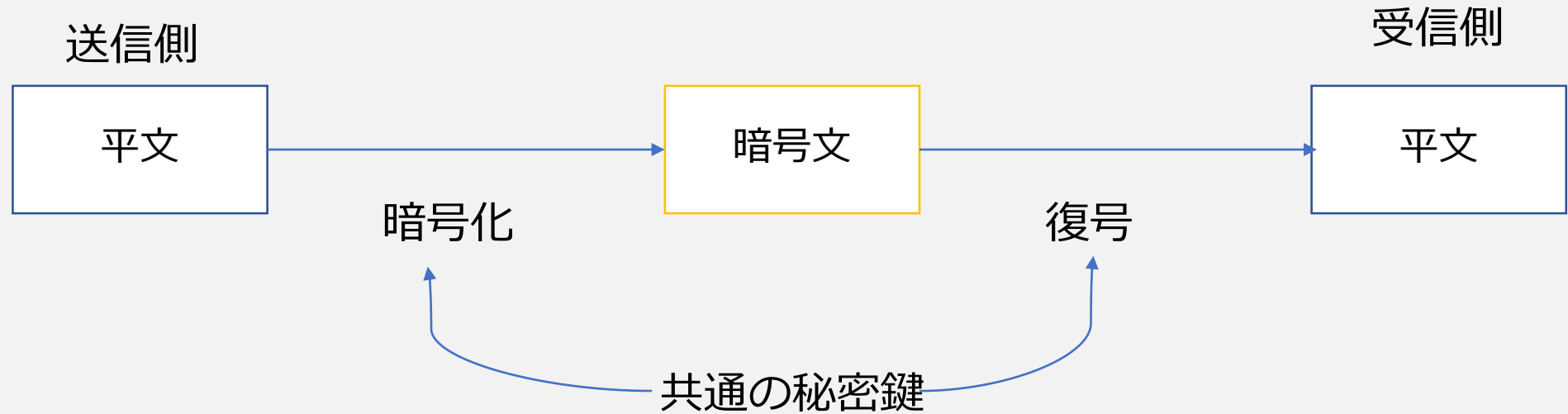
暗号化と復号に**異なる鍵**を用いる

RSA・・・素因数分解の困難さに基づいた暗号規格。

楕円曲線暗号(ECDSA)・・・ICカードなどで用いられる暗号方式。TLSなどネットワーク上のセキュリティにも用いられる

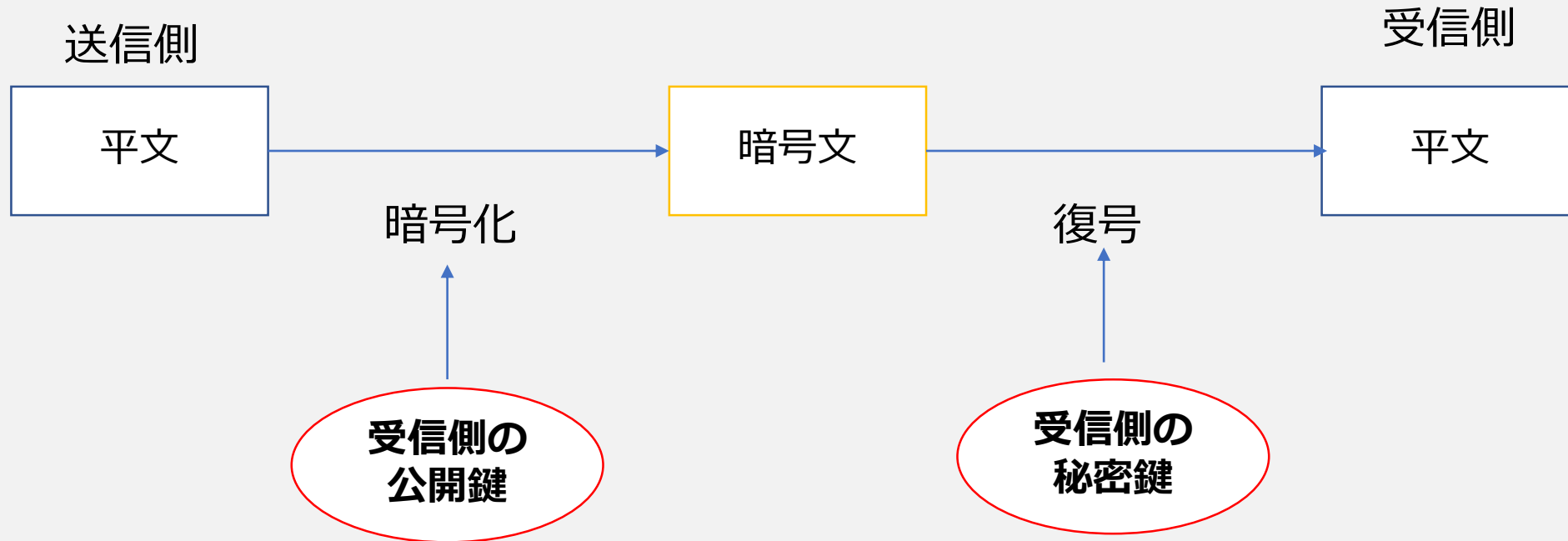
共通鍵暗号方式

あらかじめ送信者と受信者で鍵を共有して、利用する。**処理速度は高速**だが、送信対象の秘密鍵をサーバごとに持たなければいけないため、**鍵の管理が困難**



公開鍵暗号方式

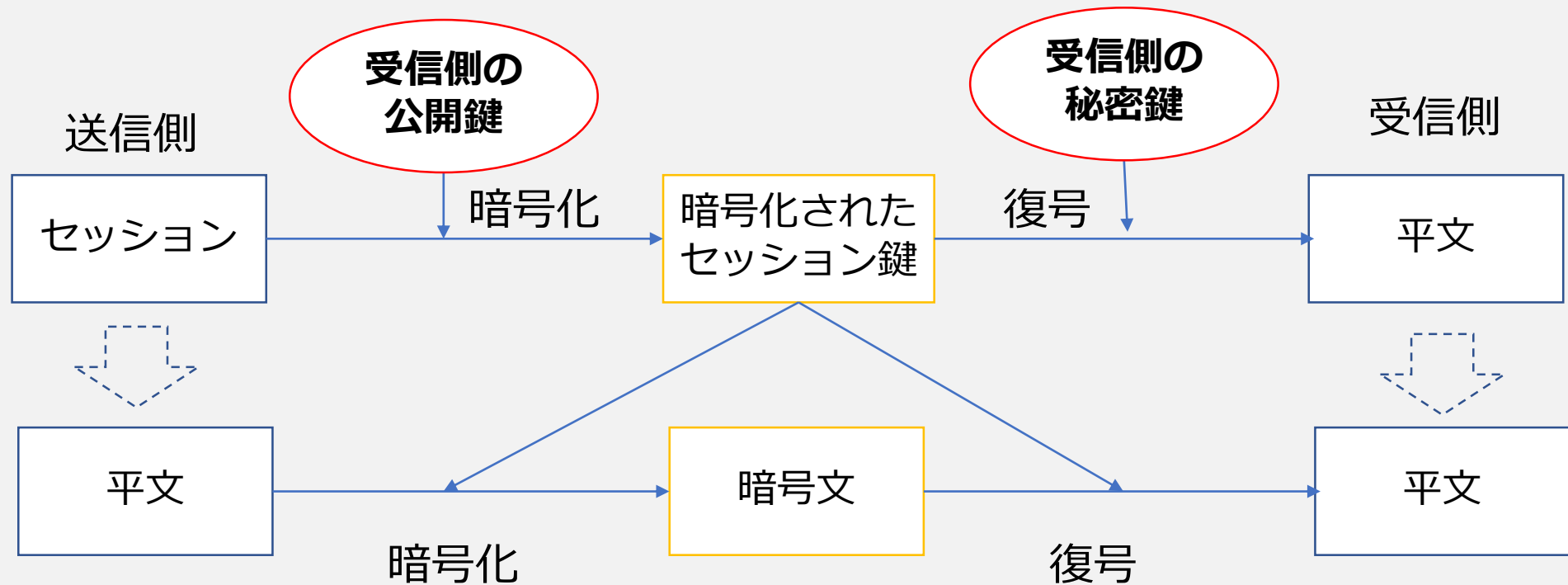
受信側の公開鍵で暗号化して、受信側の秘密鍵で復号する。一方の鍵からもう一方の鍵を推測できない。復号できるのは受信者の秘密鍵だけのため、情報の機密性を第三者から守られる。管理する必要の鍵の総数は少なく、管理するコストは小さい



セッション鍵方式(ハイブリッド暗号方式)

共通鍵暗号方式と公開鍵暗号方式を組み合わせたもので、最も主流の暗号方式。

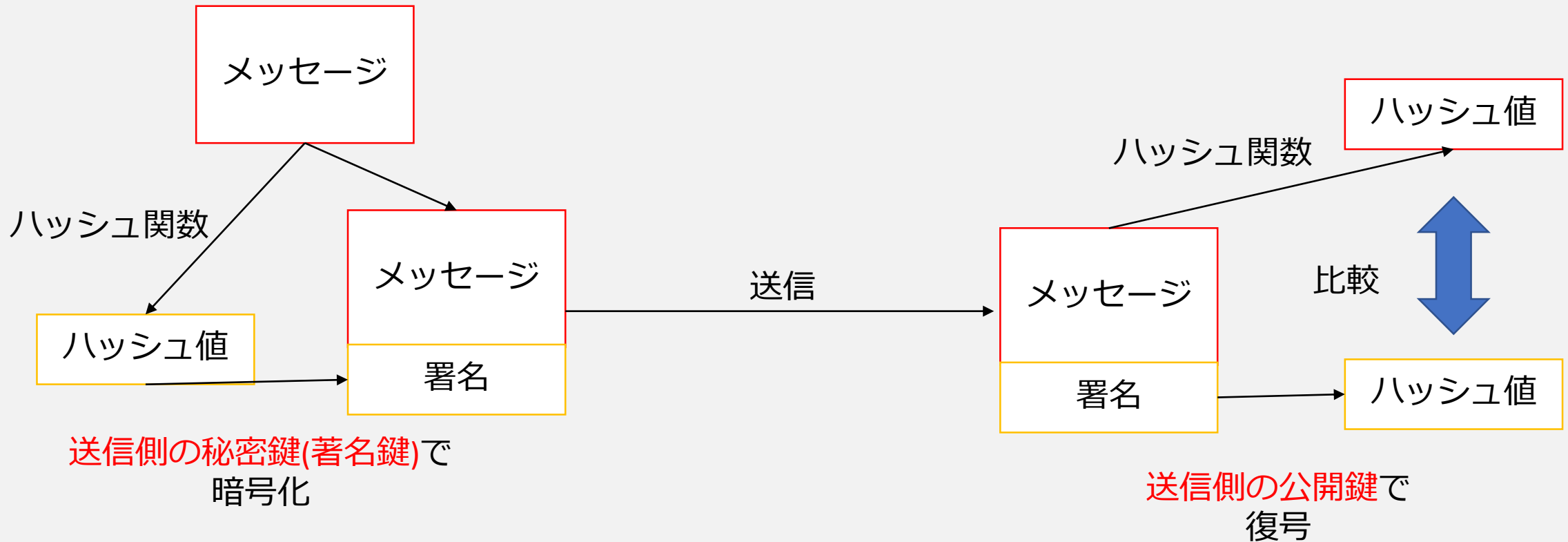
1. 送信側が**セッション鍵(共通鍵)**を作成する
2. セッション鍵を**受信側の公開鍵**で暗号化して送信する
3. 受信側は受け取った暗号化のされたセッション鍵を**秘密鍵**で復号する
4. 以後、**セッション鍵を用いた**データのやり取りをする
5. 通信が終了したら**セッション鍵を破棄**する



デジタル署名

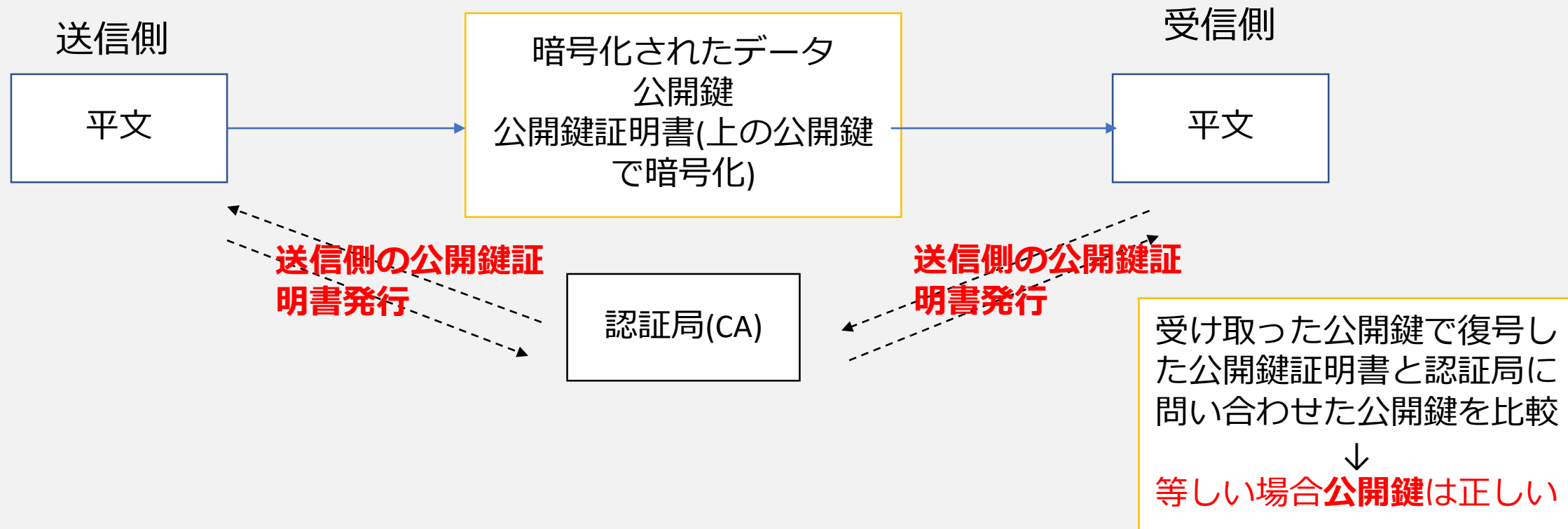
送信するメッセージの正当性を保証するための技術

- ・メッセージの送信者が本人であることを保障
- ・メッセージが改ざんされていないことを保障



PKI(公開鍵基盤)

認証局(CA)という機関が、公開鍵証明書(デジタル証明書、電子証明書)を発行して公開鍵が本人のものであることを証明する仕組み。改ざん、なりすましを検知する



CRL(証明書失効リスト)・・・CAの証明書の有効性を確認するために公開されている情報。CRLに登録されている証明書は、無効になる

時刻認証・・・メッセージにいつ作成されたか作成時刻を証明する技術。**タイムスタンプ**と呼ばれる時刻認証情報を埋め込む。タイムスタンプを発行する認証局を**時刻認証局(TSA)**と呼ぶ

応用情報技術者平成24年春期 午前問40

デジタル署名における署名鍵の使い方と、デジタル署名を行う目的のうち、適切なものはどれか。

ア.受信者が署名鍵を使って、暗号文を元のメッセージに戻すことができるようにする。

→誤り。デジタル署名ではメッセージのダイジェスト（ハッシュ値）を復号するために署名鍵を用います

イ.送信者が固定文字列を付加したメッセージを、署名鍵を使って暗号化することによって、受信者がメッセージの改ざん部位を特定できるようにする。

→誤り。デジタル署名では改ざんの有無を特定しますが、改ざん部位の特定はしないです

ウ.送信者が署名鍵を使って署名を作成し、それをメッセージに付加することによって、受信者が送信者を確認できるようにする。

→正しい。デジタル認証では、送信者の確認と改ざんの有無の検知に送信者の署名鍵を用います

エ.送信者が署名鍵を使ってメッセージを暗号化することによって、メッセージの内容を関係者以外に分からないようにする。

→誤り。メッセージ本文の暗号化は行いません

応用情報技術者平成29年秋期 午前問41

暗号方式に関する記述のうち、適切なものはどれか。

ア. AESは公開鍵暗号方式、RSAは共通鍵暗号方式の一種である。

→誤り。AESは共通鍵暗号方式、RSAは公開鍵暗号方式です

イ.共通鍵暗号方式では、暗号化及び復号に同一の鍵を使用する。

→正しい。共通鍵暗号方式の説明として正しいです

ウ.公開鍵暗号方式を通信内容の秘匿に使用する場合は、暗号化に使用する鍵を秘密にして、復号に使用する鍵を公開する。

→誤り。公開鍵は暗号化する鍵を公開して、復号する鍵を秘密にします

エ.デジタル署名に公開鍵暗号方式が使用されることはなく、共通鍵暗号方式が使用される。

→誤り。デジタル署名では公開鍵暗号方式を取ります

応用情報技術者平成30年秋期 午前問37

楕円曲線暗号に関する記述のうち、適切なものはどれか。

ア. AESに代わる共通鍵暗号方式としてNISTが標準化している。

→誤り。楕円曲線暗号は公開鍵暗号方式です

イ. 共通鍵暗号方式であり、デジタル署名にも利用されている。

→誤り。楕円曲線暗号は公開鍵暗号方式です

ウ. 公開鍵暗号方式であり、TLSにも利用されている。

→正しい。楕円曲線暗号の説明として正しいです

エ. 素因数分解問題の困難性を利用している。

→誤り。公開鍵暗号方式で用いられるRSAの説明です

基本情報技術者平成23年特別 午前問42

非常に大きな数の素因数分解が困難なことを利用した公開鍵暗号方式はどれか。

ア. AES

→誤り。最も一般的に用いられている共通鍵暗号規格。米国の国家暗号規格です

イ. DSA

→誤り。デジタル署名方式の一つです

ウ. IDEA

→正しい。共通鍵暗号方式の一つで、暗号化するデータを64ビットごとに区切り、128ビットの暗号鍵によって変換します

エ. RSA

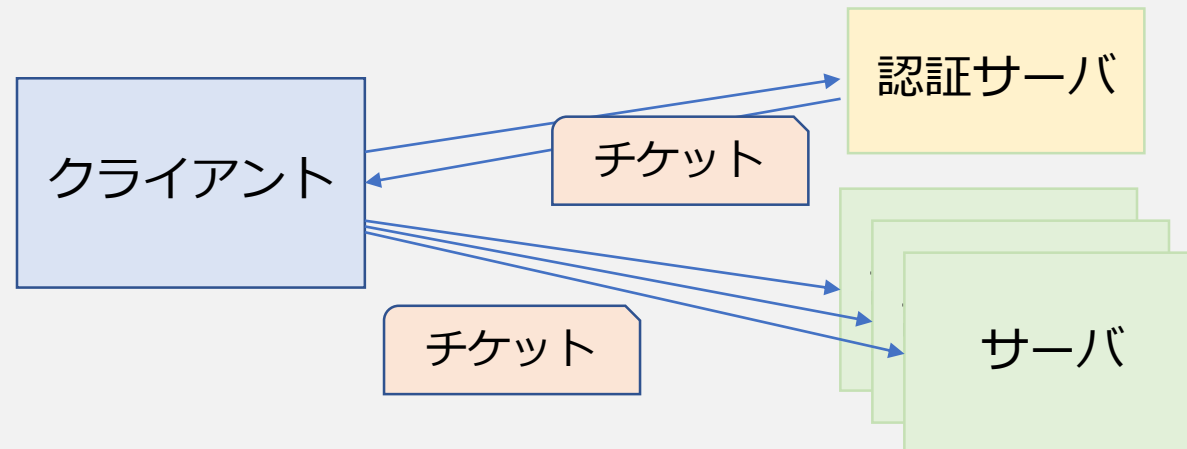
→正しい。RSAの説明です

利用者認証

ワンタイムパスワード	パスワードを毎回変更して利用する。チャレンジレスポンス方式(下記)とワンタイムパスワード生成用のハードウェア、セキュリティトークンを利用したものがある
チャレンジレスポンス方式	サーバが乱数(チャレンジ)を生成してクライアントに送信する。クライアントは、パスワードとチャレンジを組み合わせて演算した結果(レスポンス)をサーバに送る。サーバは、生成したチャレンジを変換したものとレスポンスを比較して一致した場合に認証する。データを盗聴されてもパスワードを推測できない仕組み
デバイス認証	本人しか持ちえないICカードやUSBトークンを用いて認証をする。

シングルサインオン

サーバが複数台の場合に、一度認証を受けてすべてのサーバの認証を不要とする仕組み
認証はパスワード認証もあれば、デジタル署名を用いることもあります



生体認証（バイオメトリクス認証）

生体情報を利用した認証方法で、他人がなりすますのは困難で認証の精度が高い

身体的特徴を利用	指紋・・・センサを用いて特徴点抽出、パターンマッチングで照合する 虹彩・・・虹彩（目の奥の模様）のパターンで照合する。経年劣化がほとんどないことが特徴 静脈・・・LED抗原からの赤外線照射をして、静脈のパターンを照合する
行動的特徴を利用	署名・・・署名（サイン）する際の速度・筆圧で照合する 声紋・・・音声の周波数パターンと照合する
本人拒否率(FRR)	本人を誤って認証して 拒否する確率
他人受入率(FAR)	他人を誤って認証して 許可する確率

応用情報技術者令和元年秋期 午前問45

虹彩認証に関する記述のうち、最も適切なものはどれか。

ア.経年変化による認証精度の低下を防止するために、利用者の虹彩情報を定期的に登録し直さなければならない。

→誤り。虹彩は経年劣化がほとんどないです

イ.赤外線カメラを用いると、照度を高くするほど、目に負担を掛けることなく認証精度を向上させることができる。

→誤り。照度を高めると目の負担が大きくなります

ウ.他人受入率を顔認証と比べて低くすることが可能である。

→正しい。顔認証に比較して精度は高く、顔認証で認識困難な一卵性双生児も識別できます

エ.本人が装置に接触したあとに残された遺留物を採取し、それを加工することによって認証データを偽造し、本人になりすますことが可能である。

→誤り。センサに触れることがないので指紋のような遺留物残りません

応用情報技術者平成24年秋期 午前問36

シングルサインオンの説明のうち、適切なものはどれか。

ア.クッキーを使ったシングルサインオンの場合、サーバごとの認証情報を含んだクッキーをクライアントで生成し、各サーバ上で保存、管理する。

→誤り。クッキーはサーバで生成されクライアントが保管します

イ.クッキーを使ったシングルサインオンの場合、認証対象のサーバを、異なるインターネットドメインに配置する必要がある。

→誤り。クッキーは同じドメインに対して利用されるため他のドメインで管理して、認証することができません

ウ.リバースプロキシを使ったシングルサインオンの場合、認証対象のWebサーバを、異なるインターネットドメインに配置する必要がある。

→誤り。認証対象のWebサーバは同じインターネットドメインに配置します。

エ.リバースプロキシを使ったシングルサインオンの場合、利用者認証においてパスワードの代わりにデジタル証明書を用いることができる。

→正しい。認証情報にIDとパスワードを用いるのではなくデジタル証明書を用いることは可能です

応用情報技術者平成28年秋期 午前問38

チャレンジレスポンス認証方式の特徴はどれか。

ア. TLSによって、クライアント側で固定パスワードを暗号化して送信する。

→誤り。チャレンジレスポンス認証では、固定パスワードと乱数を用います

イ. 端末のシリアル番号を、クライアント側で秘密鍵を使って暗号化して送信する。

→誤り。チャレンジレスポンス認証では、シリアル番号をもちいるのではなく、パスワードとサーバから送られるチャレンジから演算した結果（レスポンス）を送ります

ウ. トークンという装置が表示する毎回異なったデータを、パスワードとして送信する。

→誤り。ワンタイムパスワードの説明です

エ. 利用者が入力したパスワードと、サーバから送られてきたランダムなデータとをクライアント側で演算し、その結果を送信する。

→正しい。チャレンジレスポンス認証の説明です

基本情報技術者平成26年春期 午前問38

ICカードとPINを用いた利用者認証における適切な運用はどれか。

ア. ICカードによって個々の利用者を識別できるので、管理負荷を軽減するために全利用者に共通のPINを設定する。

→誤り。共通のPINではなく利用者ごとのPINを利用します

イ. ICカードの表面に刻印してある数字情報を組み合わせて、PINを設定する。

→誤り。ICカードに記載されているものを利用するとICカードから推測されるます

ウ. ICカード紛失時には、新たなICカードを発行し、PINを再設定した後で、紛失したICカードの失効処理を行う。

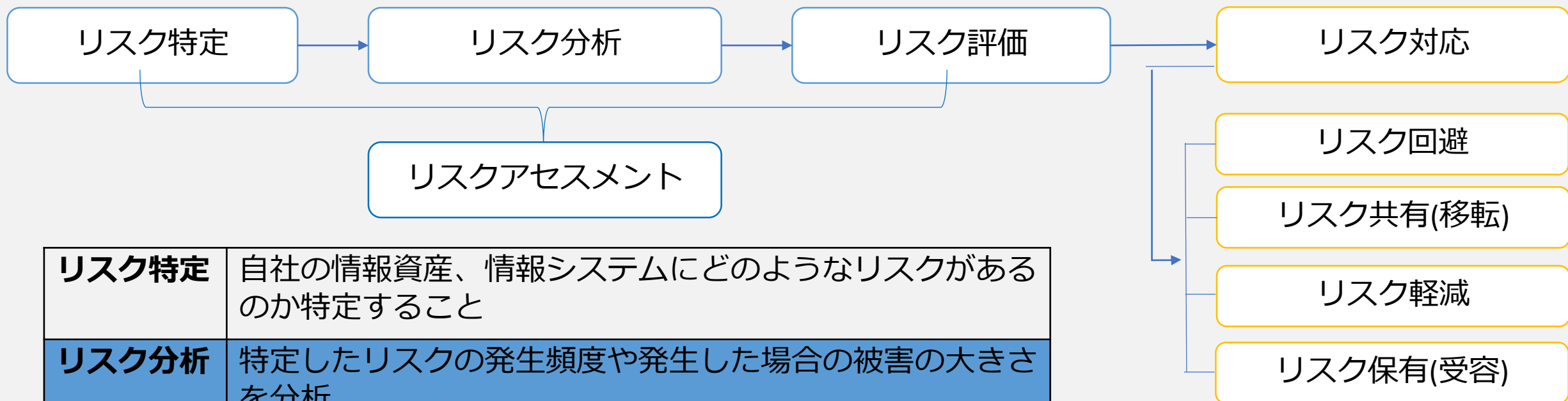
→誤り。失効処理をまず行います

エ. ICカードを配送する場合には、PINを同封せず、別経路で利用者に知らせる。

→正しい。どちらかが盗難されても不正利用を防げます

リスクマネジメント

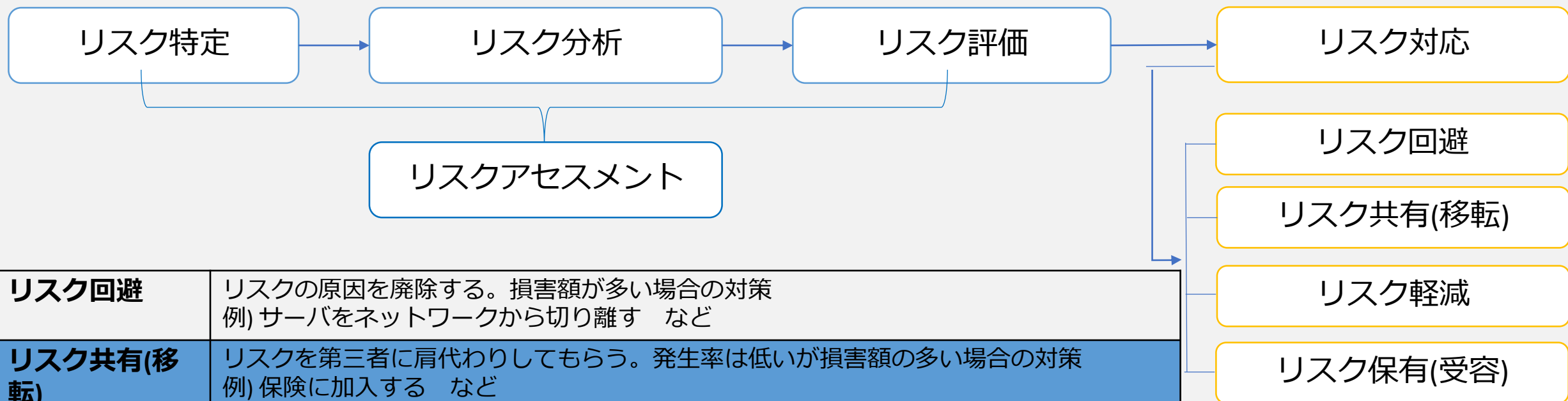
リスクマネジメントは、リスクの特定・分析・評価・対応という流れで実施される



リスク特定	自社の情報資産、情報システムにどのようなリスクがあるのか特定すること
リスク分析	特定したリスクの発生頻度や発生した場合の被害の大きさを分析
リスク評価	リスク分析の結果から各リスクの重大性を評価して対策方法を決定する

リスクマネジメント

リスクマネジメントは、リスクの特定・分析・評価・対応という流れで実施される



リスク回避	リスクの原因を廃除する。損害額が多い場合の対策 例) サーバをネットワークから切り離す など
リスク共有(移転)	リスクを第三者に肩代わりしてもらう。発生率は低いが損害額の多い場合の対策 例) 保険に加入する など
リスク軽減	リスクの発生率や損害額が少なくなるように対策をすること。発生率が高い物に対する対策 例) 暗号化。セキュリティ教育の実施 など
リスク保有(受容)	リスクをそのままにする。損害額が小さい物に対する対策

リスクファイナンス: リスクが顕在化した場合に資産面で対応すること。会社の資産や準備金、保険でまかなうこと（リスク共有やリスク保有に含まれる）

リスクアセスメント（リスクの分析）

ベースラインアプローチ	既存の基準をベースラインに設定して、リスクと比較してベースラインの水準と比較して問題がないか評価する。低コストで実施可能
詳細リスク分析	個々の情報資産の資産価値、脅威、脆弱性の評価を行う。コストがかかる手法
非形式的アプローチ	組織や担当者の知識、経験を元にリスクを評価する。最も低コストで実施可能
組み合わせアプローチ	複数のアプローチを組み合わせる

リスクアセスメント（リスクの評価）

定量的手法	予想損失額とリスクの発生確率から算出する。 $\text{リスクの評価額} = \text{予想損失額} \times \text{発生確率}$
定性的手法	情報資産の価値や脅威、脆弱性の相対的な評価を元にリスク値を算出する $\text{リスクの評価額} = \text{情報資産の価値} \times \text{脅威} \times \text{脆弱性}$

基本情報技術者平成26年秋期 午前問39

リスクアセスメントに関する記述のうち、適切なものはどれか。

ア.以前に洗い出された全てのリスクへの対応が完了する前にリスクアセスメントを実施することは避ける。

→誤り。リスクアセスメントは定期的に実行して新たなリスクを発見します

イ.将来の損失を防ぐことがリスクアセスメントの目的なので、過去のリスクアセスメントで利用されたデータを参照することは避ける。

→誤り。過去のデータを活用して有効なリスクアセスメントを行います

ウ.損失額と発生確率の予測に基づくリスクの大きさに従うなどの方法で、対応の優先順位を付ける。

→正しい。

エ.リスクアセスメントはリスクが顕在化してから実施し、損失額に応じて対応の予算を決定する。

→正しい。リスクが顕在化する前に潜在的なリスクを見つけます

基本情報技術者平成31年春期 午前問40

リスク対応のうち、リスクファイナンスに該当するものはどれか。

ア.システムが被害を受けるリスクを想定して、保険を掛ける。

→正しい。リスクファイナンスはリスクを想定してリスクが顕在化した場合に資産面で対応することです

イ.システムの被害につながるリスクの顕在化を抑える対策に資金を投入する。

→誤り。リスク低減です

ウ.リスクが大きいと評価されたシステムを廃止し、新たなセキュアなシステムの構築に資金を投入する。

→誤り。リスク回避です

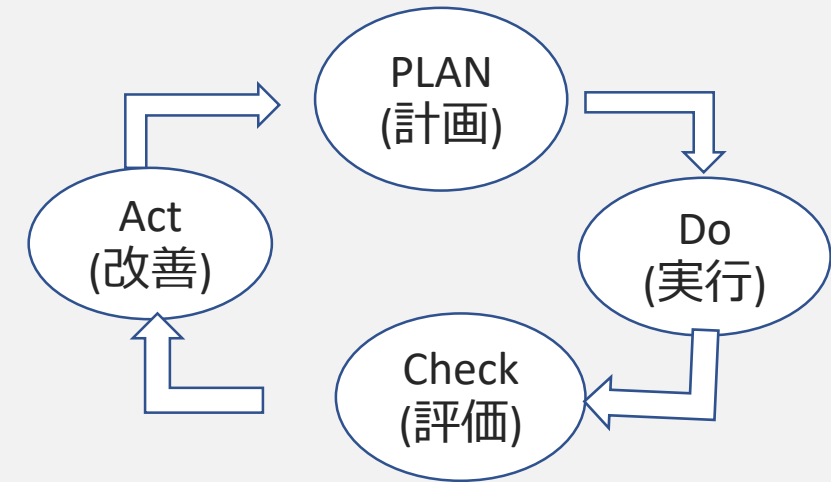
エ.リスクが顕在化した場合のシステムの被害を小さくする設備に資金を投入する。

→誤り。被害を小さくするのはリスクの低減です

情報セキュリティマネジメントシステム(ISMS)

組織全体として情報セキュリティのレベルを維持・向上していくために、継続的に対策を行っていく取り組み。

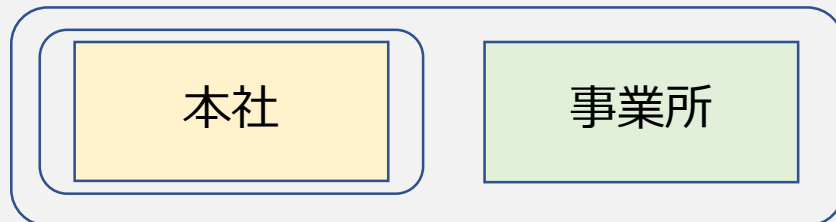
PLAN	情報セキュリティ対策の計画を立てる
Do	対策の導入・運用を行う
Check	実施した結果を監視して評価する
Act	対策の改善を行う



ISMSの確立

適用範囲と基本方針の設定	ISMSの適用範囲の決定。情報セキュリティ方針、情報セキュリティ目的の設定
リスクアセスメント	リスクの洗い出し（特定）、分析、評価を行う
リスク対応の計画	リスク対応（低減、保有、回避、移転）

適用範囲の決定



情報セキュリティ方針

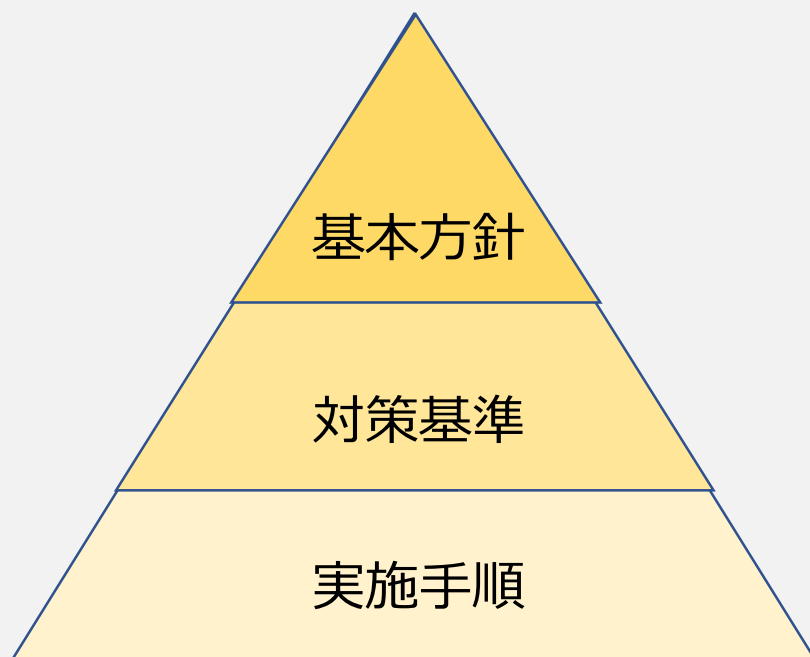
組織全体がどのように情報セキュリティに取り組むかの方針（**経営陣が決定する**）

情報セキュリティ目的

部門ごとに達成すべき目的

↑適用範囲を本社だけ、事業所を含むなど決定する

情報セキュリティポリシー



- ・・・ 情報セキュリティに関する基本的な取り組みを **経営層が決定**して周知する
- ・・・ 基本方針を実現するために、**守るべき規則や判断基準**部門ごとに異なる
- ・・・ 対策基準で決定した規則を実現するための実施手順

情報セキュリティインシデント

コンピュータの利用や情報管理、情報システム運用に関して**セキュリティ上の脅威となる事象**のこと

セキュリティインシデントの管理

インシデント対応の準備	・ インシデント対応手順の明確化 ・ 定期的なバックアップ、セキュリティパッチの適応 ・ インシデント対応の予行演習を行う
事象の検出	・ インシデントにつながる恐れのある事象の検出 ・ 状態を記録、保存する
インシデント対応	・ 対応手順を確認する ・ インシデントの発生を報告する ・ 対応を実施する
改善	・ 経営陣に報告する ・ セキュリティポリシー、手順書の修正をする

シグネチャ検出	シグネチャとは著名・定型文の意味。既知の事象の攻撃のパターンを記録して、そのパターンとマッチングして検出をする
アノマリー検出	anomalyとはある法則・理論からみて異常であったり、説明できない事象や個体等の意味。通常ではおきない異常なイベント、統計的におかしいイベントを検出する

情報セキュリティの要素

情報セキュリティのCIA・・・機密性、完全性、可用性

情報セキュリティのAAR・・・真正性、責任追跡性、信頼性、否認防止

機密性 (Confidentiality)	決められた人だけデータにアクセスできるようにすること。 例) パスワードロック、アクセス権限の設定 など
完全性 (Integrity)	データを最新かつ正しい状態で保つこと。 例) 悪意のある人からのデータ改ざんを防ぐ、バックアップを取って誤りのあった場合に戻せるようにすること。エラーチェックを行うこと
可用性 (Availability)	情報を使いたいときに使えること 例) バックアップを取得する など
真正性 (Authenticity)	利用者の身元が主張通りであることを保証すること
責任追跡性 (Accountability)	誰がいつ、どのような操作をしたのか事後に追跡できること
否認防止 (Non-Repudiation)	取引の事実が、後になって否認されることないこと
信頼性 (Reliability)	業務や情報システムが正常に機能に、矛盾があったり異常な結果で終了することがないこと

基本情報技術者平成28年秋期 午前問59

情報セキュリティ監査において、可用性を確認するチェック項目はどれか。

ア. 外部記憶媒体の無断持出しが禁止されていること

→誤り。機密性に関するチェック項目です

イ. 中断時間を定めたSLAの水準が保たれるように管理されていること

→正しい。可用性です

ウ. データ入力時のエラーチェックが適切に行われていること

→誤り。完全性に関するチェック項目です

エ. データベースが暗号化されていること

→誤り。機密性に関するチェック項目です

基本情報技術者平成26年春期 午前問39

情報セキュリティにおける"完全性"を脅かす攻撃はどれか。

ア. Webページの改ざん

→正しい。完全性を脅かす攻撃です

イ. システム内に保管されているデータの不正コピー

→誤り。機密性を脅かす攻撃です

ウ. システムを過負荷状態にするDoS攻撃

→誤り。可用性を脅かす攻撃です

エ. 通信内容の盗聴

→誤り。機密性を脅かす攻撃です

個人情報保護

個人情報保護の必要性，法律やプライバシーマーク制度などの取組

プライバシーポリシー (個人情報保護方針)	WEBサイトで、収集した個人情報をどう扱うのか（保護するのか、それとも一定条件の元に利用するのか）などを、サイトの管理者が定めた規範のこと
プライバシーマーク制度	日本産業規格「JIS Q 15001個人情報保護マネジメントシステム－要求事項」に適合して、個人情報について適切な保護措置をする体制の整備がされている事業者を評価し、プライバシーマークを付与し、事業活動に関してプライバシーマークの使用を認める制度
安全管理措置	個人情報保護法 第二十条（安全管理措置） 個人情報取扱事業者は、その取り扱う個人データの漏えい、滅失又はき損の防止その他の個人データの安全管理のために必要かつ適切な措置を講じなければならない。
サイバー保険	サイバー事故で企業に生じた第三者に対する「損害賠償責任」のほか、事故時に必要となる「費用」や自社の「喪失利益」を補填する保険

情報セキュリティ組織・機関

不正アクセスによる被害受付の対応，再発防止のための提言，情報セキュリティに関する啓発活動などを行う情報セキュリティ組織・機関の役割，及び関連する制度

情報セキュリティ委員会	情報セキュリティマネジメントシステム(ISMS)の構築を主導する委員会。経営陣が委員長を務め、メンバは組織横断的に選ばれる
SOC (Security Operation Center)	セキュリティに関する問題に対応するための組織。インシデントの予兆を捉えたり、インシデントの早期発見を行う
CSIRT	セキュリティに関する問題に対応するための組織の総称。SOCから伝えられた情報を元にインシデントを最小限に抑えるための対応をする。日本の組織は、JPSERT/CC
コンピュータ不正アクセス対策基準	コンピュータ不正アクセスによる被害の防止、発見、復旧について企業等の組織及び個人が実行すべき対策を取りまとめたもの。システムユーザ基準。システム管理者基準。ネットワークサービス事業者基準及びハードウェア・ソフトウェア供給者基準からなる
J-CSIP（サイバー情報共有インシアティブ）	IPAと各参加組織（あるいは参加組織を束ねる業界団体）間での秘密保持契約（NDA）の締結等により、参加組織およびそのグループ企業において検知されたサイバー攻撃等の情報をIPAに集約する。情報提供元に関する情報や機微情報の匿名化を行い、IPAによる分析情報を付加した上で、情報提供元の承認を得て共有可能な情報とし、参加組織間での情報共有を行っている
サイバーレスキュー隊（J-CRAT）	IPA(情報処理推進機構)が発足させた組織。企業から標的型サイバー攻撃に関する相談を受けて、被害拡大を防いで、攻撃を拡大させないための支援
NICT(内閣サイバーセキュリティセンター)	内閣官房に設置され、日本をサイバー攻撃から防衛するための司令塔となる組織

応用情報技術者平成27年春期 午前問40

JPCERT/CCの説明はどれか。

ア. 工業標準化法に基づいて経済産業省に設置されている審議会であり，工業標準化全般に関する調査・審議を行っている。

→誤り。日本工業標準調査会(JISC)の説明です

イ. 電子政府推奨暗号の安全性を評価・監視し，暗号技術の適切な実装法・運用法を調査・検討するプロジェクトであり，総務省及び経済産業省が共同で運営する暗号技術検討会などで構成される。

→誤り。CRYPTECです

ウ. 特定の政府機関や企業から独立した組織であり，国内のコンピュータセキュリティインシデントに関する報告の受付，対応の支援，発生状況の把握，手口の分析，再発防止策の検討や助言を行っている。

→正しい。JPCERT/CCの説明です

エ. 内閣官房に設置され，我が国をサイバー攻撃から防衛するための司令塔機能を担う組織である。

→誤り。NICT(内閣サイバーセキュリティセンター)です

応用情報技術者平成30年春期 午前問40

サイバーレスキュー隊(J-CRAT)は，どの脅威による被害の低減と拡大防止を活動目的としているか。

ア. クレジットカードのスキミング

→誤り。

イ. 内部不正による情報漏えい

→誤り。

ウ. 標的型サイバー攻撃

→正しい。サイバーレスキュー隊は標準型サイバー攻撃の被害低減、拡大防止を活動目的にしています

エ. 無線LANの盗聴

→誤り。

まとめ

サイバー攻撃、サイバー空間、情報資産

人的脅威の種類と特徴・・・なりすまし、クラッキング、ソーシャルエンジニアリング

技術的脅威の種類と特徴・・・ワーム、スパイウェア、ランサムウェア、ボット（BOT）、トロイの木馬、ルートキット(rootkit)、RAT、マクロウイルス、ガンプラー、キーロガー、バックドア、SPAM

脆弱性・・・セキュリティホール、バグ、人的脆弱性、シャドーIT

ハッカー、クラッカー・・・クラッカー、ホワイハッカー、スクリプトキディ、ポットハーダー(C&Cサーバー)

不正のメカニズム・・・機会、動機、正当化

攻撃手法・・・総当たり（ブルートフォース）攻撃、辞書攻撃、パスワードリスト攻撃、クロスサイトスクリプティング、SQLインジェクション、DNSキャッシュポイズニング、標的型攻撃、フィッシング攻撃、ワンクリック攻撃、ドライブバイダウンロード、DOS攻撃、DDOS攻撃、ゼロデイ攻撃、バッファオーバーフロー攻撃、MITB(Man In The Browser)攻撃、MITM(Man In The Middle)攻撃、クロスサイトリクエストフォージェリ(CSRF)、クリックジャッキング、ディレクトリトラバーサル、ドメイン名ハイジャック、セッションハイジャック、リプレイ攻撃、IPスプーフィング、Wanna Cryptor、SEOポイズニング、サラム法

対策・・・CAPTCHA

暗号技術・・・共通鍵暗号方式(AES, DES)、公開鍵暗号方式(RSA, 楕円曲線暗号(ECDSA))、セッション鍵方式(ハイブリッド暗号方式)、デジタル署名、PKI（公開鍵基盤）、CRL(証明書失効リスト)、タイムスタンプ、時刻認証局(TSA)

利用者認証・・・ワンタイムパスワード、チャレンジレスポンス認証、デバイス認証、シングルサインオン

生体認証（バイオメトリクス認証）・・・身体的特徴（指紋、虹彩、静脈）、行動的特徴（署名、声紋）、本人拒否率（FRR）、他人受入率（FAR）

まとめ

リスクマネジメント・・・リスクアセスメント（リスク特定、リスク分析、リスク評価）、リスク対応（リスク回避、リスク共有（移転）、リスク軽減、リスク保有（受容）、リスクファイナンス）

リスクアセスメント・・・ベースラインアプローチ、詳細リスク分析、非形式的アプローチ、組み合わせアプローチ、定量的手法、定性的手法

情報セキュリティマネジメントシステム（ISMS）・・・ISMSの確立（適用範囲と基本方針の設定、リスクアセスメント、リスク対応の計画）、情報セキュリティ方針、情報セキュリティ目的

情報セキュリティポリシ・・・基本方針、対策基準、実施手順

情報セキュリティインシデント

セキュリティインシデントの管理・・・インシデント対応の準備、事象の検出（シグネチャ検出、アノマリー検出）、インシデント対応、改善

情報セキュリティの要素・・・情報セキュリティのCIA(機密性、完全性、可用性)、情報セキュリティのAAR(真正性、責任追跡性、信頼性、否認防止)

個人情報保護・・・プライバシーポリシー、プライバシーマーク制度、安全管理措置、サイバー保険

情報セキュリティ組織・機関・・・情報セキュリティ委員会、SOC、CSIRT、コンピュータ不正アクセス対策基準、J-CSIP（サイバー情報共有イニシアティブ）、サイバーレスキュー隊（J-CRAT）、NICT

過去問（情報セキュリティ、情報セキュリティ管理）

「出典：応用情報技術者平成23年秋期 午前問39」

フィッシング(phishing)による被害はどれか。

ア.インターネットからソフトウェアをダウンロードしてインストールしたところ、設定したはずのない広告がデスクトップ上に表示されるようになった。

イ.インターネット上の多数のコンピュータから、公開しているサーバに一斉にパケットが送り込まれたので、当該サーバが一時使用不能になった。

ウ.知人から送信されてきた電子メールに添付されていたファイルを実行したところ、ハードディスク上にあった全てのファイルを消失してしまった。

エ."本人情報の再確認が必要なので入力してください"という電子メールで示されたURLにアクセスし、個人情報を入力したところ、詐取された。

「出典：応用情報技術者平成23年秋期 午前問39」

フィッシング(phishing)による被害はどれか。

ア.インターネットからソフトウェアをダウンロードしてインストールしたところ、設定したはずのない広告がデスクトップ上に表示されるようになった。

→誤り。スパイウェアの一種です

イ.インターネット上の多数のコンピュータから、公開しているサーバに一斉にパケットが送り込まれたので、当該サーバが一時使用不能になった。

→誤り。DDos攻撃です

ウ.知人から送信されてきた電子メールに添付されていたファイルを実行したところ、ハードディスク上にあった全てのファイルを消失してしまった。

→誤り。電子メール上のウイルス攻撃です

エ."本人情報の再確認が必要なので入力してください"という電子メールで示されたURLにアクセスし、個人情報を入力したところ、詐取された。

→正しい。フィッシングの説明です

「出典：基本情報技術者平成30年秋期 午前問41」

ボットネットにおけるc&cサーバの役割として、適切なものはどれか。

ア. Webサイトのコンテンツをキャッシュし、本来のサーバに代わってコンテンツを利用者に配信することによって、ネットワークやサーバの負荷を軽減する。

イ. 外部からインターネットを経由して社内ネットワークにアクセスする際に、CHAPなどのプロトコルを用いることによって、利用者認証時のパスワードの盗聴を防止する。

ウ. 外部からインターネットを経由して社内ネットワークにアクセスする際に、チャレンジレスポンス方式を採用したワンタイムパスワードを用いることによって、利用者認証時のパスワードの盗聴を防止する。

エ. 侵入して乗っ取ったコンピュータに対して、他のコンピュータへの攻撃などの不正な操作をするよう、外部から命令を出したり応答を受け取ったりする。

「出典：基本情報技術者平成30年秋期 午前問41」

ボットネットにおけるc&cサーバの役割として、適切なものはどれか。

ア. Webサイトのコンテンツをキャッシュし、本来のサーバに代わってコンテンツを利用者に配信することによって、ネットワークやサーバの負荷を軽減する。

→誤り。CDN(Contents Delivery System)の説明になっています

イ. 外部からインターネットを経由して社内ネットワークにアクセスする際に、CHAPなどのプロトコルを用いることによって、利用者認証時のパスワードの盗聴を防止する。

→誤り。認証サーバの説明です

ウ. 外部からインターネットを経由して社内ネットワークにアクセスする際に、チャレンジレスポンス方式を採用したワンタイムパスワードを用いることによって、利用者認証時のパスワードの盗聴を防止する。

→誤り。認証サーバの説明です

エ. 侵入して乗っ取ったコンピュータに対して、他のコンピュータへの攻撃などの不正な操作をするよう、外部から命令を出したり応答を受け取ったりする。

→正しい。ボットネットのC&Cは乗っ取ったコンピュータへ攻撃指示などを出します

「出典：応用情報技術者平成30年春期 午前問36」

企業のDMZ上で1台のDNSサーバを、インターネット公開用と、社内のPC及びサーバからの名前解決の問合せに対応する社内用とで共用している。このDNSサーバが、DNSキャッシュポイズニングの被害を受けた結果、直接引き起こされ得る現象はどれか。

ア. DNSサーバのハードディスク上に定義されているDNSサーバ名が書き換わり、インターネットからのDNS参照者が、DNSサーバに接続できなくなる。

イ. DNSサーバのメモリ上にワームが常駐し、DNS参照元に対して不正プログラムを送り込む。

ウ. 社内の利用者間の電子メールについて、宛先メールアドレスが書き換えられ、送信ができなくなる。

エ. 社内の利用者が、インターネット上の特定のWebサーバにアクセスしようとする時、本来とは異なるWebサーバに誘導される。

「出典：応用情報技術者平成30年春期 午前問36」

企業のDMZ上で1台のDNSサーバを、インターネット公開用と、社内のPC及びサーバからの名前解決の問合せに対応する社内用とで共用している。このDNSサーバが、DNSキャッシュポイズニングの被害を受けた結果、直接引き起こされ得る現象はどれか。

ア. DNSサーバのハードディスク上に定義されているDNSサーバ名が書き換わり、インターネットからのDNS参照者が、DNSサーバに接続できなくなる。

→誤り。DNSキャッシュポイズニングでDNSサーバ名が書き換わることはないです

イ. DNSサーバのメモリ上にワームが常駐し、DNS参照元に対して不正プログラムを送り込む。

→誤り。DNSキャッシュポイズニングの説明ではないです

ウ. 社内の利用者間の電子メールについて、宛先メールアドレスが書き換えられ、送信ができなくなる。

→誤り。DNSキャッシュポイズニングで宛先メールアドレスが書き換えられることはないです

エ. 社内の利用者が、インターネット上の特定のWebサーバにアクセスしようとする時、本来とは異なるWebサーバに誘導される。

→正しい。DNSサーバの被害です

「出典：応用情報技術者平成26年春期 午前問40」

安全なWebアプリケーションの作り方について、攻撃と対策の適切な組合せはどれか。

	攻撃	対策
ア	SQL インジェクション	SQL 文の組立てに静的プレースホルダを使用する。
イ	クロスサイトスクリプティング	任意の外部サイトのスタイルシートを取り込めるようにする。
ウ	クロスサイトリクエストフォージェリ	リクエストに GET メソッドを使用する。
エ	セッションハイジャック	利用者ごとに固定のセッション ID を使用する。

「出典：応用情報技術者平成26年春期 午前問40」

安全なWebアプリケーションの作り方について、攻撃と対策の適切な組合せはどれか。

	攻撃	対策
ア	SQL インジェクション	SQL 文の組立てに静的プレースホルダを使用する。
イ	クロスサイトスクリプティング	任意の外部サイトのスタイルシートを取り込めるようにする。
ウ	クロスサイトリクエストフォージェリ	リクエストに GET メソッドを使用する。
エ	セッションハイジャック	利用者ごとに固定のセッション ID を使用する。

→ア. 正しい。静的プレースホルダーを用いることでSQLインジェクションを対策することができます

イ. 誤り。スタイルシートにはJavaScriptを記載できるため、外部サイトを取り込むと攻撃用ファイルを取り込むようにされる恐れがあります

ウ. 誤り。GETメソッドを利用すればクロスサイトリクエストフォージェリを防げるわけではありません

エ. 誤り。固定のIDだとセッションハイジャックを受けやすくなります

「出典：応用情報技術者平成26年秋期 午前問36」

デジタル署名に用いる鍵の組合せのうち、適切なものはどれか。

	デジタル署名の作成に用いる鍵	デジタル署名の検証に用いる鍵
ア	共通鍵	秘密鍵
イ	公開鍵	秘密鍵
ウ	秘密鍵	共通鍵
エ	秘密鍵	公開鍵

「出典：応用情報技術者平成26年秋期 午前問36」

デジタル署名に用いる鍵の組合せのうち、適切なものはどれか。

	デジタル署名の作成に用いる鍵	デジタル署名の検証に用いる鍵
ア	共通鍵	秘密鍵
イ	公開鍵	秘密鍵
ウ	秘密鍵	共通鍵
エ	秘密鍵	公開鍵

→デジタル署名は送信者の秘密鍵で暗号化し、送信者の公開鍵で復号します
そのため**正解はエ**です

「出典：基本情報技術者令和元年秋期 午前問40」

ファイルの提供者は、ファイルの作成者が作成したファイルAを受け取り、ファイルAと、ファイルAにSHA-256を適用して算出した値Bとを利用者に送信する。そのとき、利用者が情報セキュリティ上実現できることはどれか。ここで、利用者が受信した値Bはファイルの提供者から事前に電話で直接伝えられた値と同じであり、改ざんされていないことが確認できているものとする。

ア. 値BにSHA-256を適用して値Bからデジタル署名を算出し、そのデジタル署名を検証することによって、ファイルAの作成者を確認できる。

イ. 値BにSHA-256を適用して値Bからデジタル署名を算出し、そのデジタル署名を検証することによって、ファイルAの提供者がファイルAの作成者であるかどうかを確認できる。

ウ. ファイルAにSHA-256を適用して値を算出し、その値と値Bを比較することによって、ファイルAの内容が改ざんされていないかどうかを検証できる。

エ. ファイルAの内容が改ざんされていても、ファイルAにSHA-256を適用して値を算出し、その値と値Bの差分を確認することによって、ファイルAの内容のうち改ざんされている部分を修復できる。

「出典：基本情報技術者令和元年秋期 午前問40」

ファイルの提供者は、ファイルの作成者が作成したファイルAを受け取り、ファイルAと、ファイルAにSHA-256を適用して算出した値Bとを利用者に送信する。そのとき、利用者が情報セキュリティ上実現できることはどれか。ここで、利用者が受信した値Bはファイルの提供者から事前に電話で直接伝えられた値と同じであり、改ざんされていないことが確認できているものとする。

ア. 値BにSHA-256を適用して値Bからデジタル署名を算出し、そのデジタル署名を検証することによって、ファイルAの作成者を確認できる。

→誤り。値BにSHA-256を適用してもファイルAの作成者が提供者であることを確認できません

イ. 値BにSHA-256を適用して値Bからデジタル署名を算出し、そのデジタル署名を検証することによって、ファイルAの提供者がファイルAの作成者であるかどうかを確認できる。

→誤り。値BにSHA-256を適用してもファイルAの作成者が提供者であることを確認できません

ウ. ファイルAにSHA-256を適用して値を算出し、その値と値Bを比較することによって、ファイルAの内容が改ざんされていないかどうかを検証できる。

→正しい。ファイルAにSHA-256を適用することでハッシュ値を作成できその値とBを比較してファイルAの改ざん検知ができます

エ. ファイルAの内容が改ざんされていても、ファイルAにSHA-256を適用して値を算出し、その値と値Bの差分を確認することによって、ファイルAの内容のうち改ざんされている部分を修復できる。

→誤り。差分があると改ざんの有無を検証できますが、修復はできません

「出典：基本情報技術者平成29年秋期 午前問43」

リスクアセスメントを構成するプロセスの組合せはどれか。

ア. リスク特定, リスク評価, リスク受容

イ. リスク特定, リスク分析, リスク評価

ウ. リスク分析, リスク対応, リスク受容

エ. リスク分析, リスク評価, リスク対応

「出典：基本情報技術者平成29年秋期 午前問43」

リスクアセスメントを構成するプロセスの組合せはどれか。

ア. リスク特定, リスク評価, リスク受容

イ. リスク特定, リスク分析, リスク評価

→リスクアセスメントはリスク特定、リスク分析、リスク評価の3プロセスです

ウ. リスク分析, リスク対応, リスク受容

エ. リスク分析, リスク評価, リスク対応

テクノロジー系試験範囲

1. 基礎理論

1-1. 基礎理論

離散数学/応用数学/情報に関する理論/通信に関する理論/継続・制御に関する理論

1-2. アルゴリズムとプログラミング

データ構造/アルゴリズム/プログラミング/プログラム言語/その他の言語

2. コンピュータシステム

2-1. コンピュータ構成要素

プロセッサ/メモリ/バス/入出力デバイス/入出力装置

2-2. システム構成要素

システムの構成/システムの評価指標

2-3. ソフトウェア

オペレーティングシステム/ミドルウェア/ファイルシステム/開発ツール/オープンソースソフトウェア

2-4. ハードウェア

ハードウェア

テクノロジー系試験範囲

3. 技術要素

3-1. ヒューマンインターフェース

ヒューマンインターフェース技術/インタフェース設計

3-2. マルチメディア

マルチメディア技術/マルチメディア応用

3-3. データベース

データベース方式/データベース設計/データ操作/トランザクション処理/データベース応用

3-4. ネットワーク

ネットワーク方式/データ通信と制御/通信プロトコル/ネットワーク管理/ネットワーク応用

3-5. セキュリティ

情報セキュリティ/情報セキュリティ管理/**セキュリティ技術評価/情報セキュリティ対策/情報セキュリティ実装技術**

4. 開発技術

4-1. システム開発技術

システム要件定義/システム方式設計/ソフトウェア要件定義/ソフトウェア方式設計・ソフトウェア詳細設計/ソフトウェア構築/ソフトウェア結合・ソフトウェア適格性確認テスト/ソフトウェア結合・ソフトウェア適格性確認テスト/システム結合・システム適格性確認テスト/導入/受入れ支援/保守・廃棄

4-2. ソフトウェア開発管理技術

開発プロセス・手法/知的財産権運用管理/開発環境管理/構成管理・変更管理

技術要素

セキュリティ

セキュリティ技術評価、情報セキュリティ対策、情報セキュリティ実装技術

目標：

- 人的，技術的，物理的セキュリティの側面から情報セキュリティ対策を修得する。
- ネットワーク，データベースに実装するセキュリティ対策の仕組み，実装技術，効果を修得する。
- アプリケーションセキュリティの対策の仕組み，実装技術，効果を修得する。

人的セキュリティ対策の種類

主に、以下の対策を行う

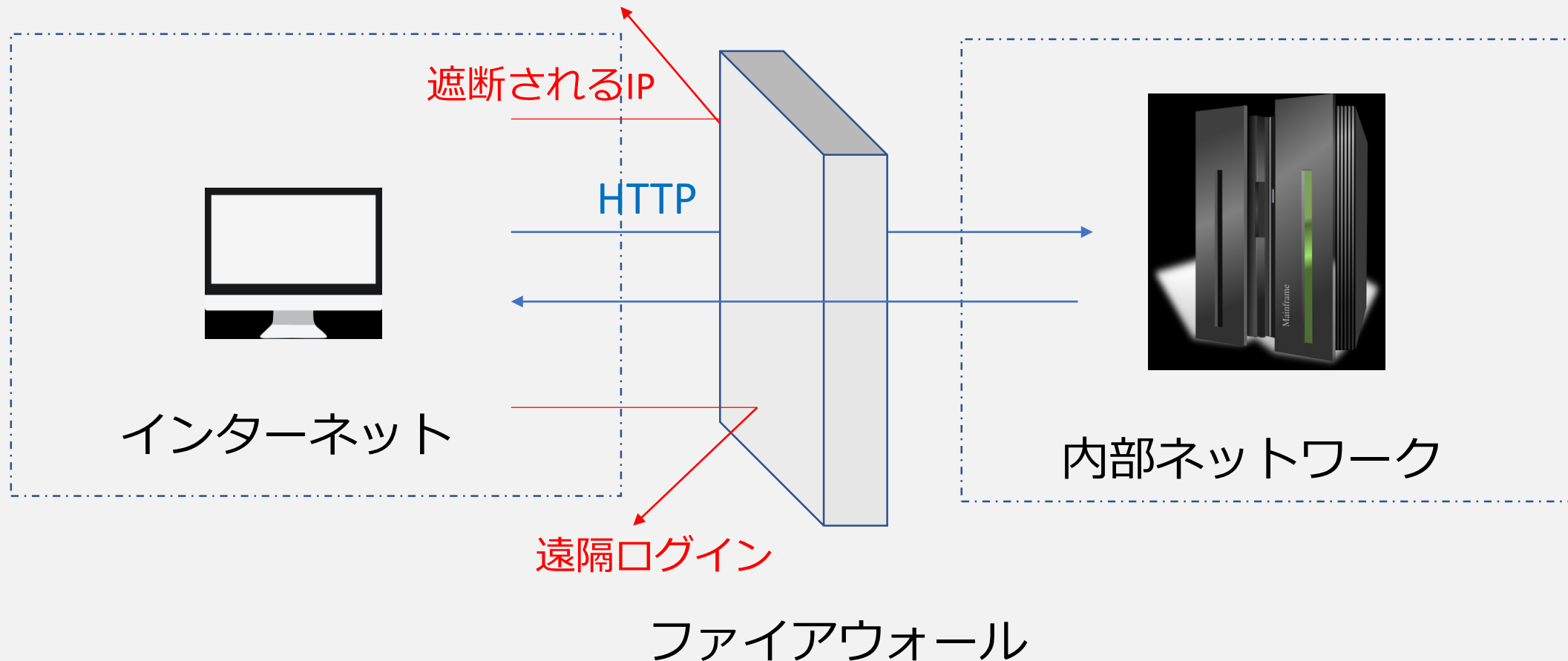
- ・ 情報セキュリティに関する教育・訓練
- ・ 情報セキュリティポリシー・各種社内規程・マニュアルの遵守
- ・ アクセス権の設定などのアクセス管理

技術的セキュリティ対策の種類

コンテンツフィルタリング	Webサイトの閲覧、利用を制限する仕組み。クライアントにインストールしたソフトウェアで行う場合と、プロキシによって通信経路上で行う場合がある
コールバック	発信者からの電話を受けた受信側が一旦回線を切断して、発信側にかかけ直すことで利用者確認を行うセキュリティ対策。
DLP(Data Loss Prevention)	機密情報の紛失や漏えいを防止する仕組みやソフトウェア。データが保存されている場所を検出し監視して、規則に違反する行為があった場合に警報を発して操作を中断する

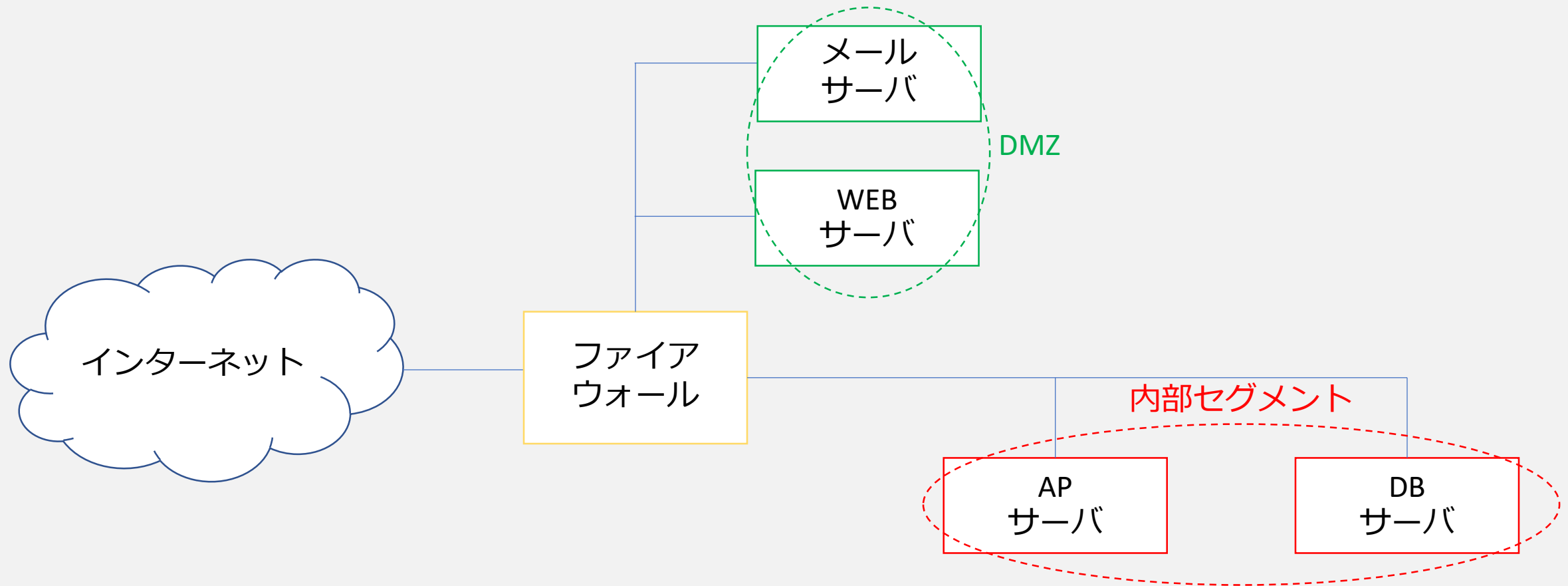
技術的セキュリティ対策の種類

ファイアウォール・・・通信内容を検査して、通過か遮断かを判断する役割。インターネットと内部ネットワークの接点に存在し、送信先、宛先のIPアドレスとポート番号を用いて不正な通信を遮断する（**パケットフィルタリング**）。このために、**フィルタリングテーブル**と呼ばれる表を設定する。



技術的セキュリティ対策の種類

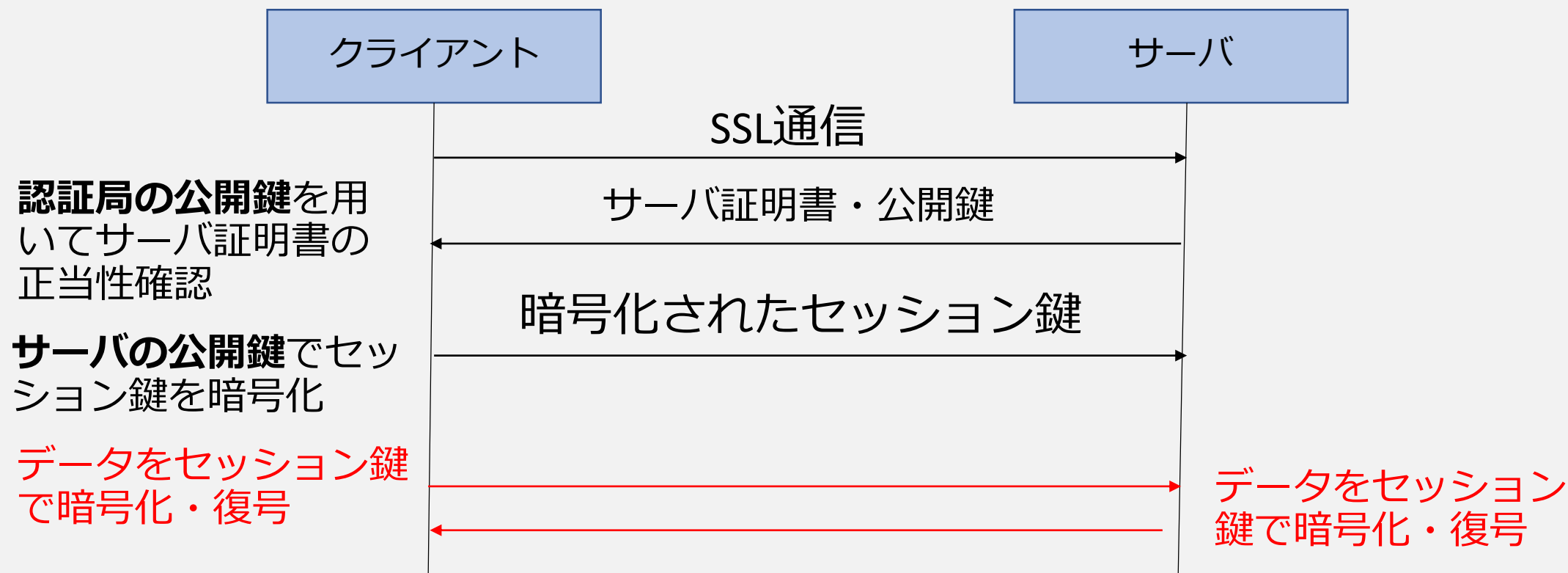
DMZ(非武装地帯)・・・インターネットを接続されている外部からアクセス可能なネットワーク、サーバ群。APサーバやDBサーバなど重要な情報の格納されたサーバは内部に配置してDMZ経由でアクセスする。



技術的セキュリティ対策の種類

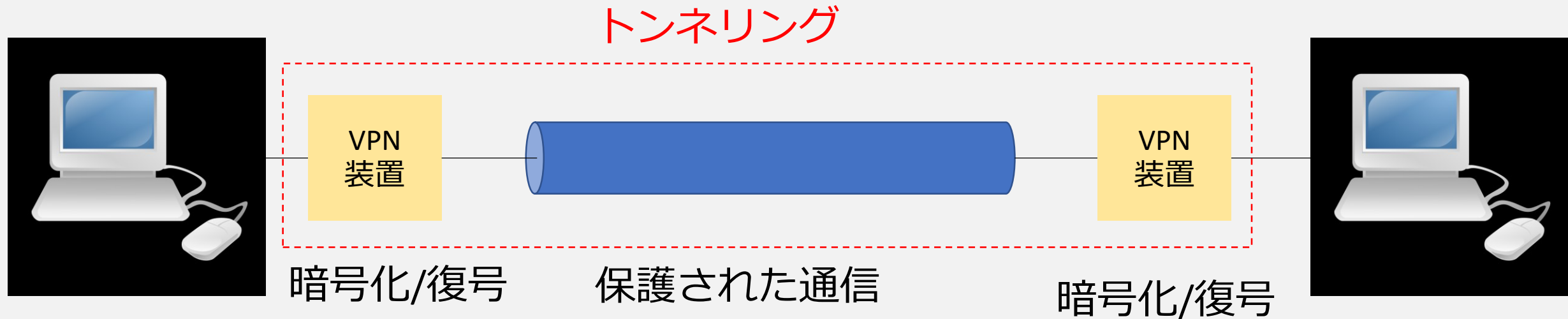
SSL/TLS . . . インターネットを用いた通信で、クライアント-サーバ間のやり取りを暗号化して安全にやり取りするプロトコル。TLSはSSLの後継規約。**暗号通信、パケットの改ざん検知、サーバ認証、クライアント認証**の機能がある。

HTTPS . . . 暗号化にSSL/TLSを用いたHTTP通信のこと



技術的セキュリティ対策の種類

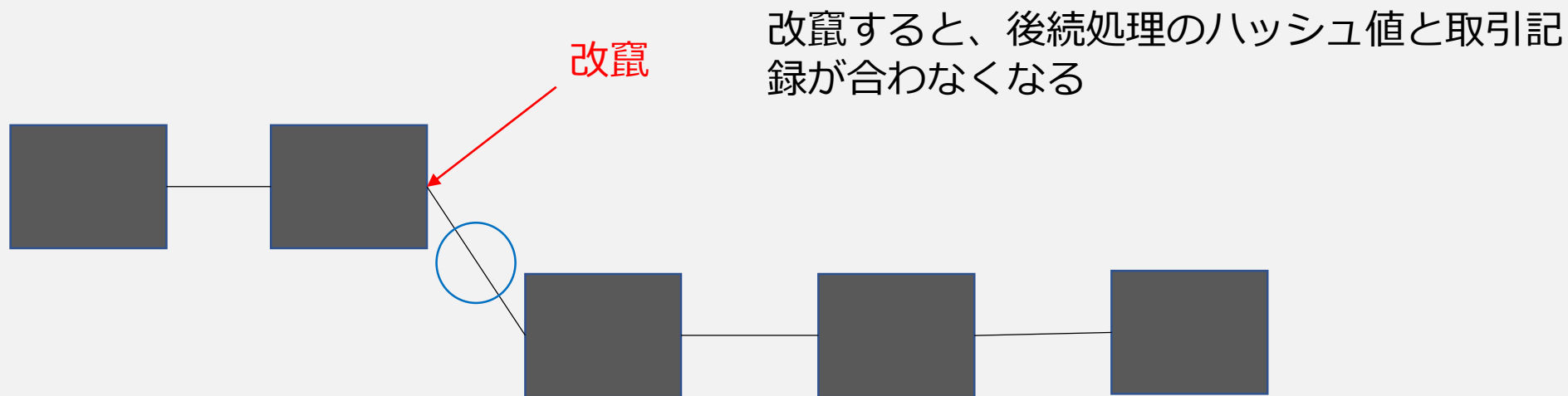
VPN・・・Virtual Private Network。セキュリティ技術を用いてインターネット上に**仮想的な専用網**を構築する仕組み。



技術的セキュリティ対策の種類

ブロックチェーン・・・取引情報を記録した分散型台帳システム。取引の**改竄ができない**仕組みになっている。銀行、公共機関のシステムで改竄防止に利用されることが期待されている

- ・取引の記録をブロックと呼ばれる記録域に格納する
- ・各ブロックに前回までの取引内容を表す情報(**ハッシュ値**)を格納する
- ・改竄があった場合、ハッシュ値とブロック値の整合性が合わなくなる

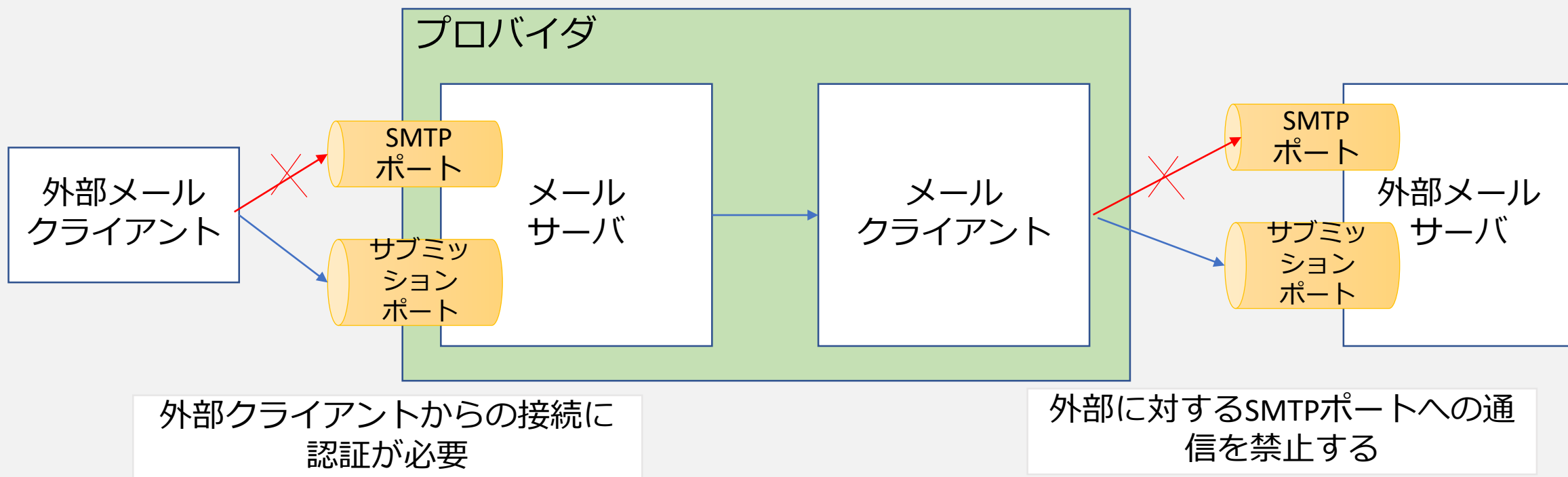


技術的セキュリティ対策の種類

S/MIME・・・電子メールの本文や添付ファイルを暗号化と改ざん検知などをする機能

SMTP-AUTH・・・電子メールの送信プロトコル（SMTP）にユーザ認証の機能を取り入れたもの

OP25B・・・Outbound port 25 blocking。25はSMTP送信に用いられるポート番号でこれまでは自由にメールを送受信されてきた。OP25Bでは、25番ポートの利用を禁止する。ユーザは必ず認証を行ってメールを送受信しなければならず、不正なメール（スパムメール）送受信を防ぐことができる



技術的セキュリティ対策の種類

ウイルス対策として以下のような対策を行います

- 出所の不明なファイルを開けない
- 怪しいWebサイトの閲覧をしない、不用意にファイルをダウンロードしない
- ウイルス対策ソフトをインストールする

ウイルス対策ソフトはパターンファイルを用いて検査を行うため、パターンファイルを常に最新状態に保つことは重要です

ウイルス検出手法

インテグリティチェック法	認証技術（デジタル署名）を用いてファイルを入手する
コンペア法	ファイルを安全に保管されている原本と比較する
チェックサム法	チェックサム値を用いてファイルが送付後と入手後で改ざんされていないか確認する
パターンマッチング法	ウイルスに特徴的なパターンがないかチェックする
ビヘイビア法	メモリ上の仮想環境下で実行して、ウイルスによって引き起こされる挙動がないか監視する

技術的セキュリティ対策の用語

アプリケーション ゲートウェイ	メール、Web閲覧などの アプリケーションレベルで制御可能なファイアウォール 。不適切なURLへの通信を遮断、不適切な単語を含むデータを遮断するなど。WAF(Web Application FireWall)はSQLインジェクション、クロスサイトスクリプティング等、アプリケーションレベルで不正アクセスを検知する
IDS, IPS	不正侵入を検知する仕組みを IDS と呼ぶ。侵入の検知だけでなく防御（通信の遮断）をするものを IPS という。
検疫ネットワーク	コンピュータがインターネットに接続する際に、コンピュータが一定のセキュリティ水準を満たしたものだけ接続できるようにすること
MDM	Mobile Device Management。スマートデバイスを従業員に貸与する場合に、 セキュリティなどの設定を統合的・効率的に管理する手法
SSH	遠隔ログイン、遠隔操作をするためのプロトコルで セッション鍵による暗号化、認証機能 を持つ
IPSEC	ネットワーク層 のセキュリティプロトコル。改ざんの検出、暗号通信を行う
デジタルフォレンジックス	不正アクセスの追跡や証拠データの解析などの操作をITを利用して行うこと。フォレンジックスとは科学捜査の意味
ペネトレーションテスト	侵入テスト。システムに脆弱性がないか確認すること
ステガノグラフィ/電子透かし	画像や音声などのデータ内に、第三者に気づかれない 情報を埋め込む技術 。利用者に気づかれないように 著作権情報 を埋め込んで不正利用を防ぐものを電子透かしという。
サンドボックス	コンピュータ内部に攻撃されてもよい仮想環境を構築して、そのなかで怪しいプログラムを動作させてウイルス等がないか確認する手法
DNSSEC	DNSサーバからの応答にデジタル署名を用いることで正当なサーバからの応答であることを確認する

応用情報技術者平成24年春期 午前問44

ステガノグラフィを説明したものはどれか。

ア. データをコピーできないようにする技術のことをいう。

→誤り。ステガノグラフィは第三者に気づかれないように情報を埋め込みます。これはコピーガードなどの説明です

イ. データを第三者に盗み見られても解読できないようにするために、決まった規則に従ってデータを変換することをいう。

→誤り。暗号化の説明です

ウ. 文書の正当性を保証するために付けられる暗号化された署名情報のことをいう。

→誤り。デジタル署名です

エ. メッセージを画像データや音声データなどに埋め込み、メッセージの存在を隠す技術のことをいう。

→正しい。ステガノグラフィの説明です

応用情報技術者平成27年秋期 午前問45

ペネトレーションテストの目的はどれか。

ア. 暗号化で使用している暗号方式と鍵長が、設計仕様と一致することを確認する。

→誤り。ペネトレーションテストは侵入テストでこれは暗号モジュールの試験です

イ. 対象プログラムの入力に対する出力結果が、出力仕様と一致することを確認する。

→誤り。ブラックボックステストです

ウ. ファイアウォールが単位時間あたりに処理できるセッション数を確認する。

→誤り。負荷試験です

エ. ファイアウォールや公開サーバに対して侵入できないかどうかを確認する。

→正しい。ペネトレーションテストの説明です

基本情報技術者平成28年春期 午前問44

デジタルフォレンジックスでハッシュ値を利用する目的として、適切なものはどれか。

ア. 一方向性関数によってパスワードを復元できないように変換して保存する。

→誤り。デジタルフォレンジックスは不正アクセスの追跡や証拠データの解析などの操作をITを利用して行うことでこれはパスワードのハッシュ値です

イ. 改変されたデータを、証拠となり得るように復元する。

→誤り。ハッシュ値からもとのデータは復元できません

ウ. 証拠となり得るデータについて、原本と複製の同一性を証明する。

→正しい。デジタルフォレンジックスでハッシュ値を用いる目的です

エ. パスワードの盗聴の有無を検証する。

→誤り。ハッシュ化しても盗聴の有無は確認できません

応用情報技術者平成28年春期 午前問40

WAFの説明として、適切なものはどれか。

ア. DMZに設置されているWebサーバへ外部から実際に侵入を試みる。

→誤り。ペネトレーションテストです

イ. WebサーバのCPU負荷を軽減するために、TLSによる暗号化と復号の処理をWebサーバではなく専用のハードウェア上で行う。

→誤り。SSL/TLSアクセラレータです

ウ. システム管理者が質問に答える形式で、自組織の情報セキュリティ対策のレベルを診断する。

→誤り。情報セキュリティ対策自己診断テストです

エ. 特徴的なパターンが含まれるかなどWebアプリケーションへの通信内容を検査して、不正な操作を遮断する。

→正しい。WAFの説明です

応用情報技術者平成25年春期 午前問36

HTTPS通信において、暗号化とサーバ認証に使用されるものはどれか。

ア. Cookie

→誤り。Cookieはブラウザに情報を保存する仕組みです

イ. S/MIME

→誤り。Secure MIMEでメールに「認証」「改ざん検知」などのセキュリティ機能を付与する技術です

ウ. SSL/TLS

→正しい。HTTPに暗号化とサーバ認証のためにSSL/TLSを付与します

エ. ダイジェスト認証

→誤り。ダイジェスト認証ではユーザ名とパスワードをMD5でハッシュ化して送ります

応用情報技術者平成26年秋期 午前問45

電子メールに用いられるS/MIMEの機能はどれか。

ア. ウイルスの検出

→誤り。S/MIMEは暗号化技術でウイルス検出を行う技術ではないです

イ. 改ざんされた内容の復元

→誤り。改ざんの検知を行いますが復元をするわけではないです

ウ. スпамメールのフィルタリング

→誤り。スパムメールのフィルタリングは行いません

エ. 内容の暗号化とデジタル署名の付与

→正しい。S/MIMEの説明です

応用情報技術者平成30年秋期 午前問44

取引履歴などのデータとハッシュ値の組みを順次つなげて記録した分散型台帳を、ネットワーク上の多数のコンピュータで同期して保有し、管理することによって、一部の台帳で取引データが改ざんされても、取引データの完全性と可用性が確保されることを特徴とする技術はどれか。

ア. MAC(Message Authentication Code)

→誤り。MACとはメッセージ認証符号です

イ. XML署名

→誤り。XML署名でXMLのなかにデジタル署名を埋め込んでセキュリティ機能を提供します

ウ. ニューラルネットワーク

→誤り。脳神経を模して作成された機械学習のためのモデルです

エ. ブロックチェーン

→正しい。ブロックチェーンの説明です

応用情報技術者平成31年春期 午前問44

パケットフィルタリング型ファイアウォールが、通信パケットの通過を許可するかどうかを判断するときに用いるものはどれか。

ア. Webアプリケーションに渡されるPOSTデータ

→誤り。

イ. 送信元と宛先のIPアドレスとポート番号

→正しい。パケットフィルタリングではIPアドレスとポート番号を用いて通信の許可を出します

ウ. 送信元のMACアドレス

→誤り。

エ. 利用者のPCから送信されたURL

→誤り。

物理的セキュリティ対策の種類

監視カメラ, 施錠管理, 入退室管理, クリアデスク・クリアスクリーン, セキュリティケーブル, 遠隔バックアップ など

無線LANのセキュリティ

WPA/WPA2・・・無線LANでの暗号通信の仕組み。WPAよりも暗号の強度を強めたものがWPA2

規格	プロトコル	暗号アルゴリズム	鍵の長さ
WPA	WPA-TKIP	RC4	128ビット
	WPA-AES	AES	128, 192, 256ビット
WPA2	WPA2-TKIP	RC4	128ビット
	WPA2-AES	CCMP(AES)	128, 192, 256ビット

MACアドレスフィルタリング・・・無線LANに接続できる端末のMACアドレスを登録できるようにして、登録のされていない端末の接続を禁止する技術

ステルスESS-ID・・・無線LANのSSIDを隠ぺいして、SSIDの知らない端末の不正接続を禁止する技術

ブロードバンドルータとPPPoE



PPPoE: PPP Over Ethernetでイーサネット上にPPPフレームをカプセル化して送信する

NAPT(IPマスカレード): ブロードバンドルータ上でプライベートIPアドレスとグローバルIPアドレスをポート番号と一緒に変換する。ポート番号を記録することで、不正なポートへのアクセスを拒否する(上の例だと送信先ポートが2000のもの以外を受け付けなくする)

IoTシステムのセキュリティ

IoT セキュリティガイドライン・・・IoT 機器やシステム、サービスに対してリスクに応じた適切なサイバーセキュリティ対策を検討するための考え方を、分野を特定せずまとめたもの

コンシューマ向け IoT セキュリティガイド・・・IoT利用者を守るためにIoT製品やシステム、サービスを提供する事業者が考慮しなければならない事柄をまとめたもの

応用情報技術者平成30年秋期 午前問45

無線LANのセキュリティプロトコル、暗号アルゴリズム、暗号鍵の鍵長の組合せのうち、適切なものはどれか。

	セキュリティプロトコル	暗号アルゴリズム	暗号鍵の鍵長
ア	WPA (TKIP)	AES	128, 192又は256ビット
イ	WPA (TKIP)	RC4	64ビット
ウ	WPA2 (CCMP)	AES	128ビット
エ	WPA2 (CCMP)	RC4	64ビット

→WPA2(CCMP)は暗号アルゴリズムがAES, 暗号鍵の鍵の長さは128ビットで正しいです

正解はウ

応用情報技術者平成26年春期 午前問43

家庭内で、PCを無線LANとブロードバンドルータを介してインターネットに接続するとき、期待できるセキュリティ上の効果の記述のうち、適切なものはどれか。

ア. IPマスカレード機能による、インターネットからの不正侵入に対する防止効果

→正しい。IPマスカレード機能(NAPT)によりポート番号を記憶し不正侵入を防止します

イ. PPPoE機能による、経路上の盗聴に対する防止効果

→誤り。経路上の盗聴防止の機能はないです

ウ. WPA機能による、不正なWebサイトへの接続に対する防止効果

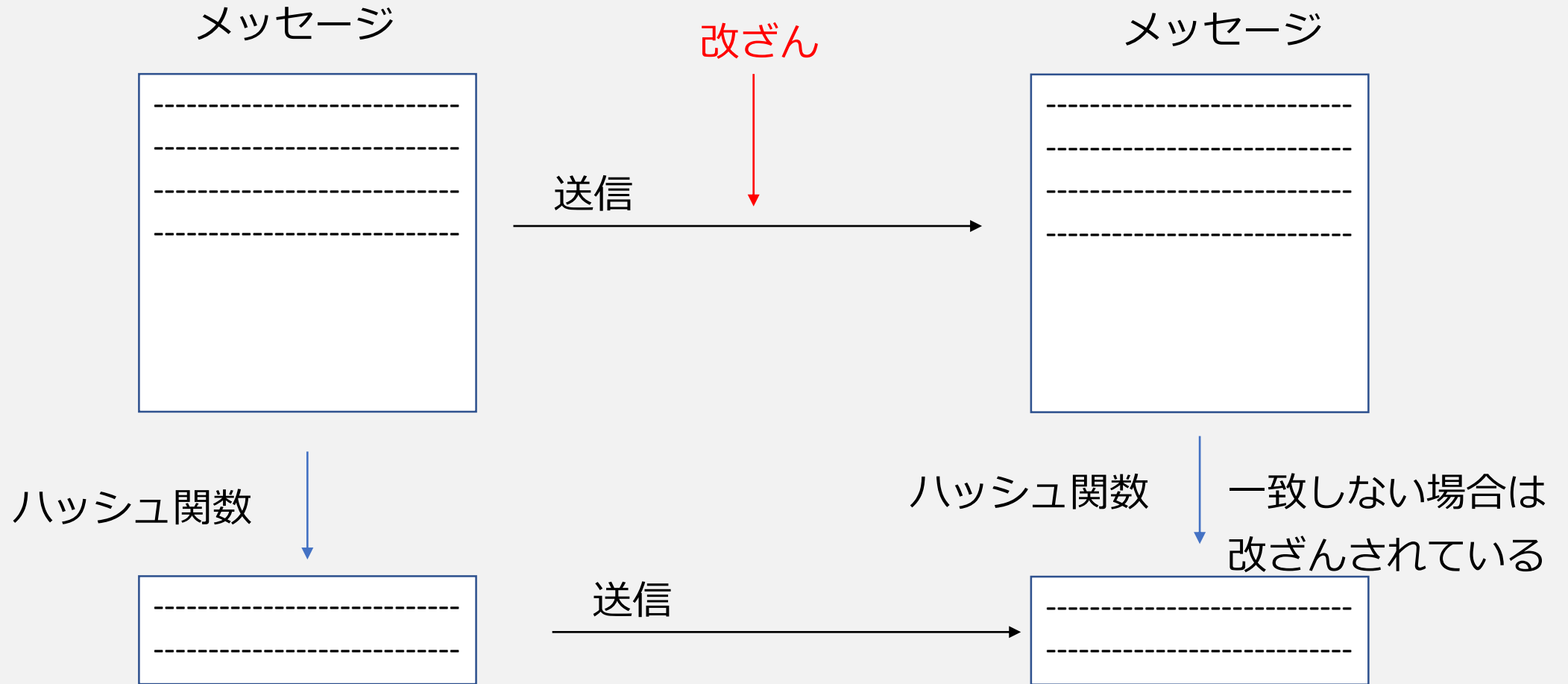
→誤り。WPAは暗号化の規格であって不正サイトへの接続防止機能はないです

エ. WPS機能による、インターネットからのウイルス感染に対する防止効果

→誤り。WPSには無線LANの接続設定を容易にする規格でウイルス感染への防止機能はないです

メッセージ認証符号(Message Authentication Code:MAC)

ハッシュ関数を用いて、メッセージの改ざん検知を行う手法



その他の情報セキュリティ対策技術

CRYPTEC暗号リスト	CRYPTECは、電子政府推奨暗号の安全性を評価・監視し、暗号技術の適切な実装法・運用法を調査・検討するプロジェクト。国が安全性を確認し、利用を推奨する暗号技術の一覧
危殆化	技術の進歩や、暗号技術の解読手法の発見などによって暗号技術が役に立たなくなること
ハニーポット	あえて攻撃者の侵入を許し、攻撃手法を分析するための機能を持ったシステム
SIEM	様々なソフトウェアの動作状況の記録（ログ）を蓄積・管理し、セキュリティの脅威となる事象をいち早く検知・分析するためのもの
バインド機構	SQLインジェクション対策に用いられる。あらかじめ、SQLの雛形を用意して一部を変数化して変数に値を割り当てSQLを実行する。 例) <code>SELECT * FROM table where = :id</code> ↑:idは変数で、:idには数値しか入れられないようにすると変なSQLが実行されない
SPF	Sender Policy Framework。メール送信元のなりすましを発見してスパムメールを発見する。電子メールを受信するサーバが電子メールの送信元のドメイン情報と、電子メールを送信したサーバのIPアドレスから、ドメインの詐称がないこと
WPA2-PSK	無線LAN（Wi-Fi）の暗号化を行うWPA/WPA2のパーソナルモード（WPA/WPA2 Personal）で、アクセスポイントと端末で通信前に共有しておくパスフレーズのこと でそのパスフレーズとSSIDを用いて端末の認証をおこなう

その他の情報セキュリティ対策技術

レッドチーム演習	セキュリティの専門家のチーム（レッドチーム）が、様々な手法で攻撃するテスト。脆弱性の発見とインシデントの対応などを総合的にテストする
ファジング	予測不能なデータを入力してプログラムの挙動を確認するテスト
耐タンパ性	内部構造やデータを外部から解析、読み取り、改ざんされにくいようにすること
プライバシーバイデザイン	テスト時でなくシステムの企画・設計時にプライバシー保護の観点で行うこと
セキュリティバイデザイン	テスト時でなくシステムの企画・設計時にセキュリティの観点で行うこと

応用情報技術者平成25年春期 午前問37

暗号アルゴリズムの危殆(たい)化を説明したものはどれか。

ア. 外国の輸出規制によって、十分な強度をもつ暗号アルゴリズムを実装した製品が利用できなくなること

→誤り。危殆化は輸出規制によるものではないです

イ. 鍵の不適切な管理によって、鍵が漏えいする危険性が増すこと

→誤り。

ウ. 計算能力の向上などによって、鍵の推定が可能になり、暗号の安全性が低下すること

→正しい。危殆化は技術進歩により暗号の安全性が低下することです

エ. 最高性能のコンピュータを用い、膨大な時間やコストを掛けて暗号強度をより確実なものにすること

→誤り。

基本情報技術者平成30年春期 午前問40

SPF(Sender Policy Framework)の仕組みはどれか。

ア. 電子メールを受信するサーバが、電子メールに付与されているデジタル署名を使って、送信元ドメインの詐称がないことを確認する。

→誤り。SPFではデジタル署名を利用するわけではありません

イ. 電子メールを受信するサーバが、電子メールの送信元のドメイン情報と、電子メールを送信したサーバのIPアドレスから、ドメインの詐称がないことを確認する。

→正しい。SPFの説明です

ウ. 電子メールを送信するサーバが、送信する電子メールの送信者の上司からの承認が得られるまで、一時的に電子メールの送信を保留する。

→誤り。SPFの説明でなくメール誤送信防止の説明です

エ. 電子メールを送信するサーバが、電子メールの宛先のドメインや送信者のメールアドレスを問わず、全ての電子メールをアーカイブする。

→正しい。SPFでなくメールのアーカイブの説明です

基本情報技術者平成31年春期 午前問38

メッセージ認証符号の利用目的に該当するものはどれか。

ア. メッセージが改ざんされていないことを確認する。

→正しい。メッセージ認証符号の目的は改ざん検知です

イ. メッセージの暗号化方式を確認する。

→誤り。

ウ. メッセージの概要を確認する。

→誤り。

エ. メッセージの秘匿性を確保する。

→誤り。

基本情報技術者平成31年春期 午前問44

侵入者やマルウェアの挙動を調査するために、意図的に脆弱性をもたせたシステム又はネットワークはどれか。

ア. DMZ

→誤り。非武装地帯のことで外部からアクセスできるサーバ、セグメントです

イ. SIEM

→誤り。SIEMは様々なソフトウェアの動作状況の記録（ログ）を蓄積・管理し、セキュリティの脅威となる事象をいち早く検知・分析するものです

ウ. ハニーポット

→正しい。ハニーポットの説明です

エ. ボットネット

→誤り。ボットネットではマルウェア感染されたPCに指示を出し攻撃する手法です

まとめ

人的セキュリティ対策・・・情報セキュリティに関する教育・訓練、情報セキュリティポリシー・各種社内規程・マニュアルの遵守、アクセス権の設定などのアクセス管理

技術的セキュリティ対策・・・コンテンツフィルタリング, コールバック, DLP(Data Loss Prevention), ファイアウォール, パケットフィルタリング, DMZ(非武装地帯), SSL/TLS, HTTPS, VPN, ブロックチェーン, S/MIME, SMTP-AUTH, OP25B, アプリケーションゲートウェイ, IDS,IPS, 検疫ネットワーク, MDM, SSH, IPSEC, デジタルフォレンジックス, ペネトレーションテスト, ステガノグラフィ/電子透かし, サンドボックス, DNSSEC

物理的セキュリティ対策・・・監視カメラ, 施錠管理, 入退室管理, クリアデスク・クリアスクリーン, セキュリティケーブル, 遠隔バックアップ など

物理的セキュリティ対策・・・WPA/WPA2, MACアドレスフィルタリング, ステルス-ESSID, ブロードバンドルータとPPPoE, IOTシステムのセキュリティ(IoTセキュリティガイドライン, コンシューマ向けIoTセキュリティガイド)

メッセージ認証符号(Message Authentication Code: MAC)

その他の情報セキュリティ対策技術・・・CRYPTEC暗号リスト、危殆化、ハニーポット、SIEM、バインド機構、SPF、WPA2-PSK、レッドチーム演習、ファジング、耐タンパ性、プライバシーバイデザイン、セキュリティバイデザイン

過去問（情報セキュリティ技術評価、情報セキュリティ対策、情報セキュリティ実装技術）

「出典：応用情報技術者平成21年春期 午前問38」

SSLによるクライアントとWebサーバ間の通信手順(1)～(5)において、a、bに入る適切な組合せはどれか。
ここで、記述した手順は、一部簡略化している。

- (1): クライアントからのSSLによる接続要求に対し、Webサーバは証明書をクライアントに送付する。
- (2): クライアントは、保持している[a]によってこのサーバ証明書の正当性を確認する。
- (3): クライアントは、共通鍵生成用のデータを作成し、サーバ証明書に添付された[b]によってこの共通鍵生成用データを暗号化し、Webサーバに送付する。
- (4): 受け取ったWebサーバは、自らの秘密鍵によって暗号化された共通鍵生成用データを復号する。
- (5): クライアントとWebサーバの両者は、同一の共通鍵生成用データによって共通鍵を作成し、これ以降の両者間の通信は、この共通鍵による暗号化通信を行う。

	a	b
ア	クライアントの公開鍵	Web サーバの秘密鍵
イ	クライアントの秘密鍵	Web サーバの公開鍵
ウ	認証局の公開鍵	Web サーバの公開鍵
エ	認証局の公開鍵	Web サーバの秘密鍵

「出典：応用情報技術者平成21年春期 午前問38」

SSLによるクライアントとWebサーバ間の通信手順(1)～(5)において、a、bに入る適切な組合せはどれか。
ここで、記述した手順は、一部簡略化している。

- (1): クライアントからのSSLによる接続要求に対し、Webサーバは証明書をクライアントに送付する。
- (2): クライアントは、保持している[a]によってこのサーバ証明書の正当性を確認する。
- (3): クライアントは、共通鍵生成用のデータを作成し、サーバ証明書に添付された[b]によってこの共通鍵生成用データを暗号化し、Webサーバに送付する。
- (4): 受け取ったWebサーバは、自らの秘密鍵によって暗号化された共通鍵生成用データを復号する。
- (5): クライアントとWebサーバの両者は、同一の共通鍵生成用データによって共通鍵を作成し、これ以降の両者間の通信は、この共通鍵による暗号化通信を行う。

	a	b
ア	クライアントの公開鍵	Web サーバの秘密鍵
イ	クライアントの秘密鍵	Web サーバの公開鍵
ウ	認証局の公開鍵	Web サーバの公開鍵
エ	認証局の公開鍵	Web サーバの秘密鍵

→SSLによる通信では、認証局の公開鍵で証明書の正当性を確認し、サーバの公開鍵で共通鍵生成用のデータを暗号化します

よって**正解はウ**

「出典：応用情報技術者平成30年秋期 午前問40」

インターネットに接続された利用者のPCから、DMZ上の公開Webサイトにアクセスし、利用者の個人情報を入力すると、その個人情報が内部ネットワークのデータベース(DB)サーバに蓄積されるシステムがある。このシステムにおいて、利用者個人のデジタル証明書を用いたTLS通信を行うことによって期待できるセキュリティ上の効果はどれか。

ア. PCとDBサーバ間の通信データを暗号化するとともに、正当なDBサーバであるかを検証することができるようになる。

イ. PCとDBサーバ間の通信データを暗号化するとともに、利用者を認証することができるようになる。

ウ. PCとWebサーバ間の通信データを暗号化するとともに、正当なDBサーバであるかを検証することができるようになる。

エ. PCとWebサーバ間の通信データを暗号化するとともに、利用者を認証することができるようになる。

「出典：応用情報技術者平成30年秋期 午前問40」

インターネットに接続された利用者のPCから、DMZ上の公開Webサイトにアクセスし、利用者の個人情報を入力すると、その個人情報が内部ネットワークのデータベース(DB)サーバに蓄積されるシステムがある。このシステムにおいて、利用者個人のデジタル証明書を用いたTLS通信を行うことによって期待できるセキュリティ上の効果はどれか。

ア. PCとDBサーバ間の通信データを暗号化するとともに、正当なDBサーバであることを検証することができるようになる。

→誤り。TLS通信を用いて通信するのは利用者PCとWebサーバ間です

イ. PCとDBサーバ間の通信データを暗号化するとともに、利用者を認証することができるようになる。

→誤り。DMZを介しており、PCとDBサーバ間を直接通信することはありません

ウ. PCとWebサーバ間の通信データを暗号化するとともに、正当なDBサーバであることを検証することができるようになる。

→誤り。利用者の認証にデジタル証明書を用いており、正当なDBサーバの検証には用いません

エ. PCとWebサーバ間の通信データを暗号化するとともに、利用者を認証することができるようになる。

→正しい。

「出典：基本情報技術者平成29年春期 午前問43」

1台のファイアウォールによって、外部セグメント、DMZ、内部セグメントの三つのセグメントに分割されたネットワークがある。このネットワークにおいて、Webサーバと、重要なデータをもつデータベースサーバから成るシステムを使って、利用者向けのサービスをインターネットに公開する場合、インターネットからの不正アクセスから重要なデータを保護するためのサーバの設置方法のうち、最も適切なものはどれか。ここで、ファイアウォールでは、外部セグメントとDMZとの間及びDMZと内部セグメントとの間の通信は特定のプロトコルだけを許可し、外部セグメントと内部セグメントとの間の直接の通信は許可しないものとする。

ア. WebサーバとデータベースサーバをDMZに設置する。

イ. Webサーバとデータベースサーバを内部セグメントに設置する。

ウ. WebサーバをDMZに、データベースサーバを内部セグメントに設置する。

エ. Webサーバを外部セグメントに、データベースサーバをDMZに設置する。

「出典：基本情報技術者平成29年春期 午前問43」

1台のファイアウォールによって、外部セグメント、DMZ、内部セグメントの三つのセグメントに分割されたネットワークがある。このネットワークにおいて、Webサーバと、重要なデータをもつデータベースサーバから成るシステムを使って、利用者向けのサービスをインターネットに公開する場合、インターネットからの不正アクセスから重要なデータを保護するためのサーバの設置方法のうち、最も適切なものはどれか。ここで、ファイアウォールでは、外部セグメントとDMZとの間及びDMZと内部セグメントとの間の通信は特定のプロトコルだけを許可し、外部セグメントと内部セグメントとの間の直接の通信は許可しないものとする。

ア. WebサーバとデータベースサーバをDMZに設置する。

イ. Webサーバとデータベースサーバを内部セグメントに設置する。

ウ. WebサーバをDMZに、データベースサーバを内部セグメントに設置する。

→正しい。WebサーバをDMZにしてデータベースサーバを内部セグメントに配置します

エ. Webサーバを外部セグメントに、データベースサーバをDMZに設置する。

「出典：応用情報技術者平成27年秋期 午前問39」

無線LAN環境におけるWPA2-PSKの機能はどれか。

ア. アクセスポイントに設定されているSSIDを共通鍵とし，通信を暗号化する。

イ. アクセスポイントに設定されているのと同じSSIDとパスワード(Pre-Shared Key)が設定されている端末だけを接続させる。

ウ. アクセスポイントは，IEEE 802.11acに準拠している端末だけに接続を許可する。

エ. アクセスポイントは，利用者ごとに付与されたSSIDを確認し，無線LANへのアクセス権限を識別する。

「出典：応用情報技術者平成27年秋期 午前問39」

無線LAN環境におけるWPA2-PSKの機能はどれか。

ア. アクセスポイントに設定されているSSIDを共通鍵とし，通信を暗号化する。

→誤り。SSIDを共通鍵とするわけではありません

イ. アクセスポイントに設定されているのと同じSSIDとパスワード(Pre-Shared Key)が設定されている端末だけを接続させる。

→正しい。あらかじめパスワードを共有してSSIDとパスワードを用いて接続します

ウ. アクセスポイントは，IEEE 802.11acに準拠している端末だけに接続を許可する。

→誤り。パスワードとSSIDで通信するのであって、IEEE 802.11acに準拠している端末に接続を許可するのではないです

エ. アクセスポイントは，利用者ごとに付与されたSSIDを確認し，無線LANへのアクセス権限を識別する。

→誤り。利用者ごとにSSIDを付与するわけではないです

「出典：応用情報技術者平成29年秋期 午前問44」

ICカードの耐タンパ性を高める対策はどれか。

ア. ICカードとICカードリーダとが非接触の状態で利用者を認証して，利用者の利便性を高めるようにする。

イ. 故障に備えてあらかじめ作成した予備のICカードを保管し，故障時に直ちに予備カードに交換して利用者がICカードを使い続けられるようにする。

ウ. 信号の読み出し用プローブの取付けを検出するとICチップ内の保存情報を消去する回路を設けて，ICチップ内の情報を容易に解析できないようにする。

エ. 利用者認証にICカードを利用している業務システムにおいて，退職者のICカードは業務システム側で利用を停止して，ほかの利用者が使用できないようにする。

「出典：応用情報技術者平成29年秋期 午前問44」

ICカードの耐タンパ性を高める対策はどれか。

ア. ICカードとICカードリーダとが非接触の状態で利用者を認証して，利用者の利便性を高めるようにする。

→誤り。非接触性と耐タンパ性とは関係がないです。

イ. 故障に備えてあらかじめ作成した予備のICカードを保管し，故障時に直ちに予備カードに交換して利用者がICカードを使い続けられるようにする。

→誤り。予備カードと耐タンパ性とは関係がないです。

ウ. 信号の読み出し用プローブの取付けを検出するとICチップ内の保存情報を消去する回路を設けて，ICチップ内の情報を容易に解析できないようにする。

→正しい。耐タンパ性は内部構造やデータを外部から解析、読み取り、改ざんされにくいようにすることで正しい説明です

エ. 利用者認証にICカードを利用している業務システムにおいて，退職者のICカードは業務システム側で利用を停止して，ほかの利用者が使用できないようにする。

→誤り。セキュリティ向上の対策です

「出典：応用情報技術者平成30年春期 午前問42」

ファジングに該当するものはどれか。

ア. サーバにFINパケットを送信し，サーバからの応答を観測して，稼働しているサービスを見つけ出す。

イ. サーバのOSやアプリケーションソフトが生成したログやコマンド履歴などを解析して，ファイルサーバに保存されているファイルの改ざんを検知する。

ウ. ソフトウェアに，問題を引き起こしそうな多様なデータを入力し，挙動を監視して，脆弱性を見つけ出す。

エ. ネットワーク上を流れるパケットを収集し，そのプロトコルヘッダやデータを解析して，あらかじめ登録された攻撃パターンと一致した場合は不正アクセスと判断する。

「出典：応用情報技術者平成30年春期 午前問42」

ファジングに該当するものはどれか。

ア. サーバにFINパケットを送信し，サーバからの応答を観測して，稼働しているサービスを見つけ出す。
→誤り。ポートスキャンの説明です

イ. サーバのOSやアプリケーションソフトが生成したログやコマンド履歴などを解析して，ファイルサーバに保存されているファイルの改ざんを検知する。
→誤り。ログ分析です

ウ. ソフトウェアに，問題を引き起こしそうな多様なデータを入力し，挙動を監視して，脆弱性を見つけ出す。

→正しい。ファジングの説明です

エ. ネットワーク上を流れるパケットを収集し，そのプロトコルヘッダやデータを解析して，あらかじめ登録された攻撃パターンと一致した場合は不正アクセスと判断する。
→誤り。パターンマッチングです

「出典：応用情報技術者平成31年春期 午前問40」

DNSSECについての記述のうち、適切なものはどれか。

ア. DNSサーバへの問合せ時の送信元ポート番号をランダムに選択することによって、DNS問合せへの不正な応答を防止する。

イ. DNSの再帰的な問合せの送信元として許可するクライアントを制限することによって、DNSを悪用したDoS攻撃を防止する。

ウ. 共通鍵暗号方式によるメッセージ認証を用いることによって、正当なDNSサーバからの応答であることをクライアントが検証できる。

エ. 公開鍵暗号方式によるデジタル署名を用いることによって、正当なDNSサーバからの応答であることをクライアントが検証できる。

「出典：応用情報技術者平成31年春期 午前問40」

DNSSECについての記述のうち、適切なものはどれか。

ア. DNSサーバへの問合せ時の送信元ポート番号をランダムに選択することによって、DNS問合せへの不正な応答を防止する。

→誤り。DNSSECの回答ではないです

イ. DNSの再帰的な問合せの送信元として許可するクライアントを制限することによって、DNSを悪用したDoS攻撃を防止する。

→誤り。DoS攻撃の対策であり、DNSSECとは異なります

ウ. 共通鍵暗号方式によるメッセージ認証を用いることによって、正当なDNSサーバからの応答であることをクライアントが検証できる。

→誤り。メッセージ認証は改ざん検知の技術でクライアントからの応答を検知するものではないです

エ. 公開鍵暗号方式によるデジタル署名を用いることによって、正当なDNSサーバからの応答であることをクライアントが検証できる。

→正しい。DNSSECの説明です

「出典：応用情報技術者平成28年秋期 午前問44」

サンドボックス機構に該当するものはどれか。

ア. OS, データベース, アプリケーション, ネットワーク機器など多様なソフトウェアや機器が出力する大量のログデータを分析する。

イ. Webアプリケーションの入力フォームの入力データに含まれるHTMLタグ, JavaScript, SQL文などを他の文字列に置き換えることによって, 入力データ中に含まれる悪意のあるプログラムの実行を防ぐ。

ウ. Webサーバの前段に設置し, 不特定多数のPCから特定のWebサーバへのリクエストに代理応答する。

エ. 不正な動作の可能性があるプログラムを特別な領域で動作させることによって, 他の領域に悪影響が及ぶのを防ぐ。

「出典：応用情報技術者平成28年秋期 午前問44」

サンドボックス機構に該当するものはどれか。

ア. OS, データベース, アプリケーション, ネットワーク機器など多様なソフトウェアや機器が出力する大量のログデータを分析する。

→誤り。SIEMの説明です

イ. Webアプリケーションの入力フォームの入力データに含まれるHTMLタグ, JavaScript, SQL文などを他の文字列に置き換えることによって, 入力データ中に含まれる悪意のあるプログラムの実行を防ぐ。

→誤り。これはサニタイジングと呼ばれています

ウ. Webサーバの前段に設置し, 不特定多数のPCから特定のWebサーバへのリクエストに代理応答する。

→誤り。リバースプロキシの説明です

エ. 不正な動作の可能性があるプログラムを特別な領域で動作させることによって, 他の領域に悪影響が及ぶを防ぐ。

→正しい。サンドボックスの説明です

「出典：応用情報技術者平成25年秋期 午前問41」

ビヘイビア法のウイルス検出手法に当たるものはどれか。

ア. あらかじめ検査対象に付加された，ウイルスに感染していないことを保証する情報と，検査対象から算出した情報とを比較する。

イ. 検査対象と安全な場所に保管してあるその原本とを比較する。

ウ. 検査対象のハッシュ値と既知のウイルスファイルのハッシュ値とを比較する。

エ. 検査対象をメモリ上の仮想環境下で実行して，その挙動を監視する。

「出典：応用情報技術者平成25年秋期 午前問41」

ビエイビア法のウイルス検出手法に当たるものはどれか。

ア. あらかじめ検査対象に付加された，ウイルスに感染していないことを保証する情報と，検査対象から算出した情報とを比較する。

→誤り。チェックサム法などです

イ. 検査対象と安全な場所に保管してあるその原本とを比較する。

→誤り。コンペア法です

ウ. 検査対象のハッシュ値と既知のウイルスファイルのハッシュ値とを比較する。

→誤り。チェックサム法です

エ. 検査対象をメモリ上の仮想環境下で実行して，その挙動を監視する。

→正しい。ビエイビア法の説明です

「出典：基本情報技術者令和元年秋期 午前問64」

システム開発の上流工程において、システム稼働後に発生する可能性がある個人情報の漏えいや目的外利用などのリスクに対する予防的な機能を検討し、その機能をシステムに組み込むものはどれか。

ア. 情報セキュリティ方針

イ. セキュリティレベル

ウ. プライバシーバイデザイン

エ. プライバシーマーク

「出典：基本情報技術者令和元年秋期 午前問64」

システム開発の上流工程において、システム稼働後に発生する可能性がある個人情報の漏えいや目的外利用などのリスクに対する予防的な機能を検討し、その機能をシステムに組み込むものはどれか。

ア. 情報セキュリティ方針

→誤り。情報セキュリティの目標とその目標を達成するために決める施策です

イ. セキュリティレベル

→誤り。セキュリティレベルはシステムに必要なセキュリティ要件のことです

ウ. プライバシーバイデザイン

→正しい。プライバシーバイデザインの説明です

エ. プライバシーマーク

→誤り。「JIS Q 15001個人情報保護マネジメントシステム－要求事項」に適合して、個人情報について適切な保護措置をする体制の整備がされている事業者を評価するためのマークです